

An Operational Executive, Architecture & Engineering Playbook

A federated operating model for turning AI ambition into governed, measurable, production-grade value — from strategy, process and portfolio to infrastructure, platform, agents, risk, incident response and economics.

VERSION

1.2

PUBLISHED

24 August 2026

AUTHOR

Mohan Arumugam

BASIS

Evidence-based synthesis

Prepared for **Boards & C-suite, CIO / CTO / CDAO, Engineering & Platform Leaders, Enterprise & Solution Architects, AI/ML, Risk, Security and Finance** functions.

A Vendor-Neutral Framework

Contents

Enterprise AI Transformation Framework & Playbook — Version 1.2

FRONT MATTER

How to Read This Framework	4
Executive Summary	5

PART I — STRATEGY & PORTFOLIO

1	Transformation Mandate & Outcomes	7
2	Sponsors, Stakeholders & Decision Rights	8
3	Strategy & AI Maturity	10
4	Business Process Transformation	12
5	Use-Case Discovery, Prioritization & Portfolio	14
6	AI Business Case & Benefits Realization	16

PART II — ENTERPRISE AI ARCHITECTURE

7	AI Technology Evolution	18
8	Enterprise AI Reference Architecture (Logical View)	20
9	AI Infrastructure Architecture	21
10	Data Foundation & Knowledge Architecture	24
11	Generative AI, Agents & Agentic AI	26

PART III — AI PLATFORM & ENGINEERING

12	Enterprise AI Platform Blueprint	29
13	Models & Vendor Strategy	31
14	AI Platform Engineering & GenAIOps	33
15	AI Evaluation, Quality Engineering & Observability	34

PART IV — RISK, SECURITY & COMPLIANCE

16	Responsible AI, Governance, Risk & Compliance	36
----	---	----

17	AI Cybersecurity Architecture	38
18	AI Incident Management	40
PART V — OPERATING MODEL & ECONOMICS		
19	Operating Model & Organization Design	42
20	AI Economics: TCO, Tokenomics & FinOps	44
21	Vendor & Procurement Strategy	47
PART VI — DELIVERY & OVERSIGHT		
22	Implementation Timeline & Roadmap	49
23	Executive Dashboards & KPIs	51
24	Change Management & Adoption	53
25	AI Technical Debt & Continuous Improvement	55
26	Templates & Reference Artifacts	56
27	Reference Architecture Patterns	58
APPENDICES — REFERENCE TEMPLATES		
A	AI Transformation Charter	59
B	AI System Card	60
C	Model Evaluation Plan	61
D	AI Risk Register	62
E	Agent Tool Register	64
F	Production Readiness Checklist	65
G	Source Register	66
H	Framework Refresh Cycle	68
I	Architecture Decision Record (ADR)	69
J	Model Selection Matrix	70
K	Build / Buy / Partner / Open-Weight Scorecard	71

L	AI Business Case & Benefits Realization Template	72
M	AI Maturity Assessment Worksheet	73
N	AI Incident Report	74
O	Vendor Due Diligence Checklist	75
P	AI Resilience & Disaster Recovery Matrix	76
Q	Change Impact & Workforce Transition Worksheet	77

FRONT MATTER

How to Read This Framework

This is a practitioner synthesis for executive and technical decision-making — not an ISO or NIST standard in itself.

EVIDENCE DISCIPLINE

Source-backed statements are tagged **[R#]** and traced to Appendix G. Recommendations, sample timelines, formulas and templates are explicitly framework guidance or illustrative, not benchmarks. Vendor capabilities, model availability, pricing and regulatory obligations change quickly and must be revalidated at design and procurement time. This version (1.2) has been checked against primary sources as of **24 August 2026**; see the revision note in Appendix G. Version 1.2 deepens the framework operationally — infrastructure architecture, platform blueprint, incident management, business-case discipline and technical-debt management are new — rather than simply extending it.

FRONT MATTER

Executive Summary

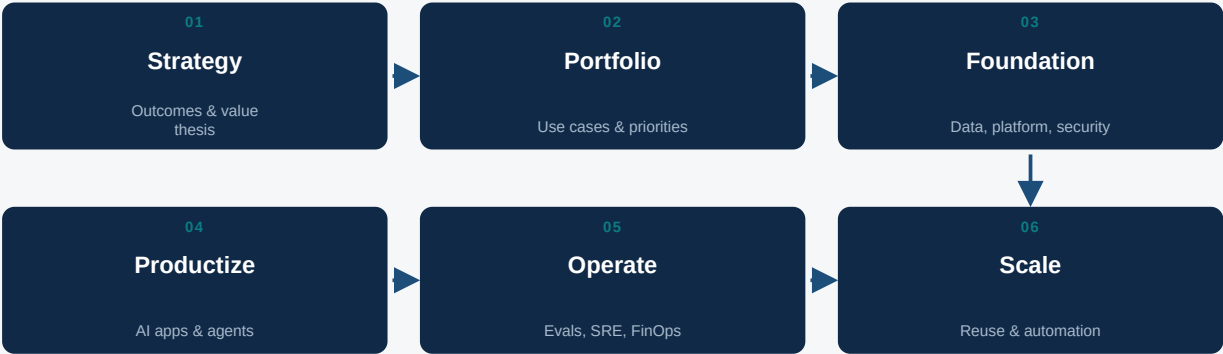
Enterprise AI transformation is an operating-model transformation, not an LLM procurement exercise.

It connects business strategy, data, AI platforms, software engineering, risk, security, people, finance and measurable outcomes. The recommended model is **federated**: a central AI platform / control plane provides reusable capabilities and guardrails, while domain product teams own production outcomes. Seven commitments anchor the framework:

- ◆ Start with business outcomes and process pain, not model selection.
- ◆ Create an AI portfolio and tier use cases by value, risk, autonomy and data sensitivity.
- ◆ Build nine reusable platform services: model gateway, prompt/config registry, knowledge/RAG, agent runtime, developer portal, identity/security, evaluation, observability and FinOps.
- ◆ Treat AI evaluation as continuous quality engineering: golden sets, adversarial tests, regression gates and production feedback.
- ◆ Manage token economics as unit economics: cost/request, cost/task, cost/outcome and value/task.
- ◆ Use risk-tiered governance; NIST AI RMF / GenAI Profile [R1][R2] and ISO/IEC 42001 [R3] are core reference points.
- ◆ Scale through product teams, platform engineering, standards, reusable patterns and workforce enablement.

6 stages FEDERATED TRANSFORMATION LIFECYCLE	9 REUSABLE PLATFORM SERVICES	5 tiers AGENT AUTONOMY & RISK GATING	27 CHAPTERS + 17 PRACTICAL APPENDICES
---	--	--	---

Figure FM.1. Enterprise AI transformation lifecycle — framework synthesis.



Governance, risk, security, architecture and value management span every stage.

Six recurring stages, run iteratively per use case and in aggregate across the portfolio.

1

PART I — STRATEGY & PORTFOLIO

Transformation Mandate & Outcomes

The transformation objective is to create a repeatable system that converts business opportunities into safe, measurable and economically viable AI products.

Anchor the mandate in seven outcome lenses. Each should carry an executive question the sponsor can answer in one sentence, and an evidence trail that proves the answer in production.

Outcome	Executive question	Evidence
Growth	Where can AI improve revenue/conversion?	Revenue, conversion, retention
Productivity	Which workflows can be accelerated?	Cycle time, throughput, hours avoided
Customer	Can AI reduce friction safely?	CSAT, resolution time
Risk	Can AI reduce losses or improve controls?	Loss avoided, detection rate
Engineering	Can AI increase delivery leverage?	Lead time, defects, automation
Knowledge	Can employees access knowledge faster?	Time-to-answer, success rate
Differentiation	Which AI capabilities become strategic IP?	Product differentiation, data flywheel

FRAMING PRINCIPLE

The transformation mandate fails when it is framed as “adopt an LLM.” It succeeds when it is framed as “convert named business opportunities into governed, measured production systems, repeatably.”

2

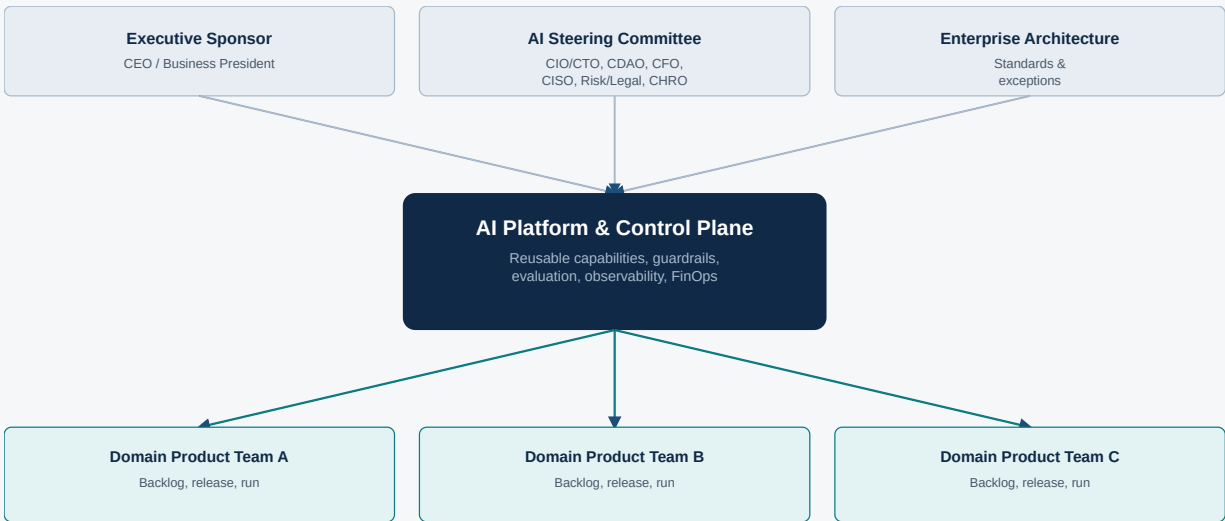
PART I — STRATEGY & PORTFOLIO

Sponsors, Stakeholders & Decision Rights

Enterprise AI crosses organizational boundaries. Use an executive sponsor plus a cross-functional steering committee and federated product ownership.

Role	Accountability	Decision rights
CEO / Business President	Strategic ambition	Enterprise priorities / investment
CIO / CTO	Technology transformation	Platform / architecture
CDAO / Chief AI Officer	AI & data strategy	Standards / portfolio
CFO	Economic value	Funding / unit economics
Business Heads / COO	Domain outcomes	Use-case ownership
CISO	Security	Security controls / risk acceptance
Risk / Compliance / Legal / Privacy	AI risk and obligations	Risk / legal gates
CHRO	Workforce / change	Skills / role redesign
Enterprise Architecture	Target architecture	Standards / exceptions
AI Platform / CoE	Reusable capabilities	Patterns / tooling
Domain Product Teams	Production outcomes	Backlog / releases / operations

Figure 2.1. Federated AI governance operating model.



Decision-rights principle: centralize standards and shared platform capabilities; decentralize business outcomes and product delivery.

Decision forums & escalation ladder

Four standing forums keep decisions moving without collapsing everything onto one body. Terminology note: the **AI Council** is the standing executive governance body named in the operating model (Chapter 19); it conducts its recurring business through the **AI Steering Committee** forum below — the two are the same body viewed as a structure versus a meeting, not separate bodies.

Forum	Cadence	Decides	Chair
AI Steering Committee	Monthly	Portfolio funding, risk appetite, standards exceptions	AI Council Chair (Executive Sponsor)
Domain AI Product Review	Bi-weekly	Backlog, release readiness, adoption	Domain product owner
AI Risk & Architecture Review Board	Per gate (PoC → Pilot → Prod)	Risk tier sign-off, architecture conformance	CISO / Chief Architect
AI Platform Working Group	Weekly	Shared services roadmap, incident retrospectives	AI Platform lead

ESCALATION RULE

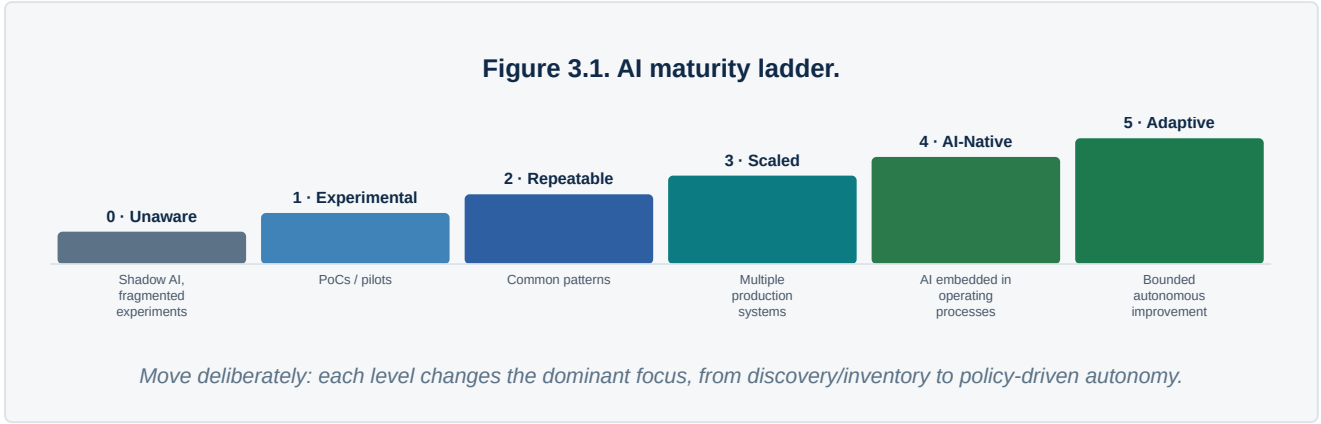
Escalation ladder: a decision blocked at a lower forum for more than one cycle escalates automatically to the next forum up — it is not left to the blocked team to ask. The AI Steering Committee is the terminal escalation point short of the Board.

3

PART I — STRATEGY & PORTFOLIO

Strategy & AI Maturity

Position the enterprise on a six-level maturity curve before setting targets — the correct next investment differs by level.



Level	Characteristics	Focus
0 — Unaware	Shadow AI, fragmented experiments	Discover / inventory
1 — Experimental	PoCs / pilots	Guardrails + funnel
2 — Repeatable	Common patterns	Standardize delivery
3 — Scaled	Multiple production systems	Portfolio + reliability + economics
4 — AI-Native	AI embedded in operating processes	Continuous optimization
5 — Adaptive	Bounded autonomous improvement	Policy-driven autonomy

- 1 Define business ambition and measurable outcomes.
- 2 Set risk appetite and prohibited / high-risk categories.
- 3 Define architecture principles: security, data, interoperability, provider strategy and observability.
- 4 Define portfolio horizons: productivity, customer, operations, revenue and strategic differentiation.
- 5 Define funding, benefits realization, skills and a 12/24-month roadmap.

Maturity assessment dimensions & scoring rubric

Score each of eight dimensions 0–5 against the maturity ladder above; the companion workbook's *Maturity Assessment* sheet automates the weighted roll-up and flags the constraining (lowest-scoring) dimension.

Dimension	What “good” looks like at level 3+	Weight
Strategy & sponsorship	Executive mandate, funding continuity, outcome clarity	15%

Dimension	What “good” looks like at level 3+	Weight
Portfolio & governance	Intake, prioritization, gating, kill discipline	15%
Data foundation	Discoverability, quality, access, lineage	15%
Platform & engineering	Reusable services, GenAIOps, developer experience	15%
Risk, security & compliance	Inventory, controls, evaluation gates	15%
Operating model & skills	Roles, funding model, capability depth	10%
Economics & FinOps	Unit-cost visibility, budget discipline	10%
Adoption & change	Usage, trust, workforce transition	5%

SCORING RULE

The overall maturity level is capped at the lowest-scoring dimension, not the weighted average. An enterprise scoring 4 on platform engineering but 1 on risk/security is a level-1 enterprise for gating purposes — the constraint, not the average, determines what is safe to scale.

4

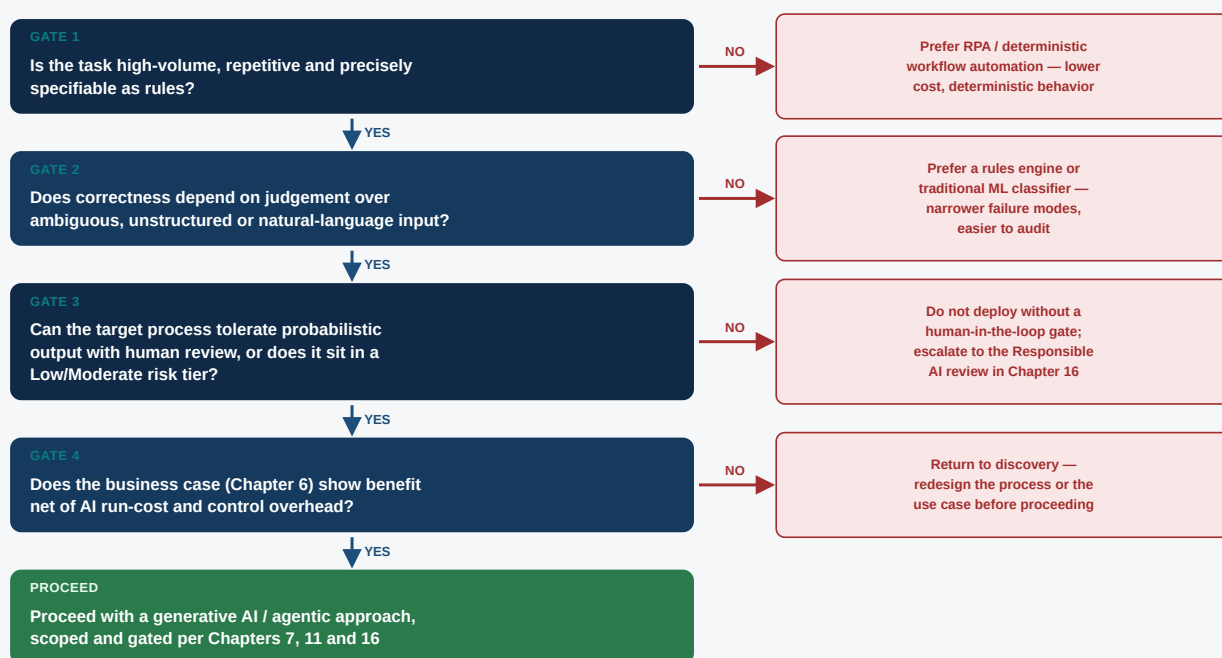
PART I — STRATEGY & PORTFOLIO

Business Process Transformation

AI is one of several process-improvement instruments. Selecting it correctly — and refusing it when it is the wrong instrument — is itself a governance control.

Before any use case reaches the portfolio funnel (Chapter 5), it should pass through a process-transformation lens: is this a process redesign question with an AI-shaped answer, or an automation, integration, or policy question wearing an AI label? Enterprises that skip this step tend to over-apply generative AI to deterministic, high-volume back-office steps that RPA or a rules engine would serve more cheaply and more predictably, and under-apply it to judgement-heavy, unstructured-input steps where it earns its cost.

Figure 4.1. When should I use generative AI versus another instrument?



Every candidate should clear this cascade before entering the use-case funnel in Chapter 5. Failing a gate is a valid, expected outcome — not a failure of the intake process.

The process-transformation toolkit

Instrument	Description	When it fits
Eliminate	Remove the step entirely	Legacy approval step no longer required post-digitization
Automate (deterministic)	RPA, workflow engine, rules	Structured data entry, high-volume reconciliation
Predict (traditional ML)	Classification, scoring, forecasting	Fraud scoring, demand forecasting

Instrument	Description	When it fits
Assist (generative AI)	Draft, summarize, retrieve, recommend	Case summarization, knowledge search, first-draft generation
Act (agentic AI)	Multi-step execution within bounded autonomy	Multi-system reconciliation with approval gates
Redesign	Change the process shape, not just the tooling	Straight-through processing replacing sequential handoffs

Worked example — loan origination

A retail-lending origination process illustrates the cascade in practice. The end-to-end journey has six steps; each was routed to a different instrument rather than defaulting every step to a single "AI project."

Journey step	Instrument selected	Design note	Risk posture
Application intake	Assist (generative AI)	RAG-grounded document extraction with human verification of extracted fields	Moderate — human-reviewed before use
Identity & fraud checks	Predict (traditional ML)	Existing fraud-scoring model, unchanged	Existing control regime
Credit decisioning	Predict (traditional ML) + Assist	ML score remains the decision system; GenAI drafts the adverse-action explanation for human sign-off	High — regulated decision, human accountable
Document generation	Assist (generative AI)	Template-grounded generation of disclosures and agreements	Moderate — template-constrained, reviewed
Case correspondence	Assist (generative AI)	Draft responses to applicant queries, agent-in-the-loop send	Low-Moderate — human sends
Portfolio monitoring	Agentic AI (bounded)	Scheduled agent flags exception accounts for underwriter review; cannot itself change terms	Moderate — read + flag only, no write access

DESIGN PRINCIPLE

The credit decision itself stayed on the existing, validated ML scoring model — generative AI was deliberately kept out of the regulated decision boundary and confined to drafting the human-reviewed explanation. This is the pattern to default to for regulated decisions: AI drafts, an accountable human decides.

5

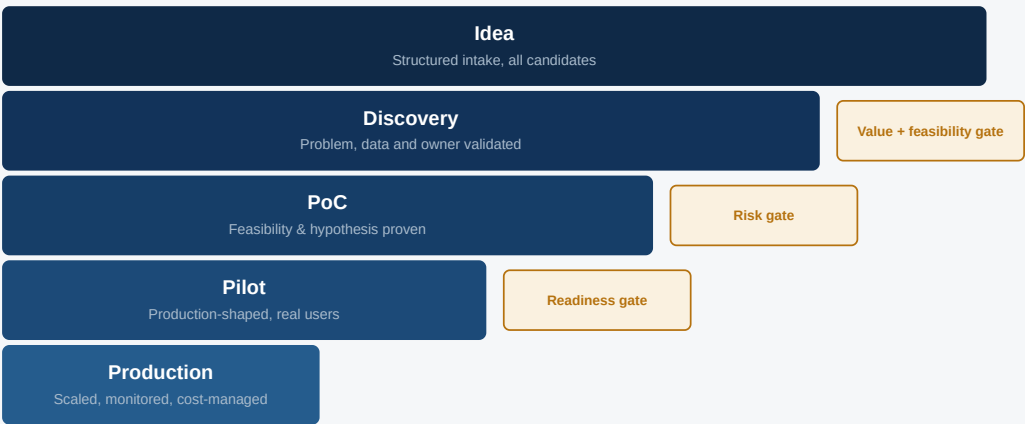
PART I — STRATEGY & PORTFOLIO

Use-Case Discovery, Prioritization & Portfolio

Every candidate use case answers eleven standard questions before it enters the portfolio backlog — after clearing the process-transformation cascade in Chapter 4:

Field	Required question
Business problem	What problem exists without AI?
Owner	Who owns the business outcome?
Users	Who consumes / depends on it?
KPI / baseline	What measurable metric changes?
AI hypothesis	Why should AI improve it?
Data	What data is required / owned?
Decision / action	Advise, recommend, generate or execute?
Risk / autonomy	What happens if it is wrong?
Integration	Which systems / APIs are needed?
Economics	Cost per task vs. value per task?
Exit criteria	When should the use case stop?

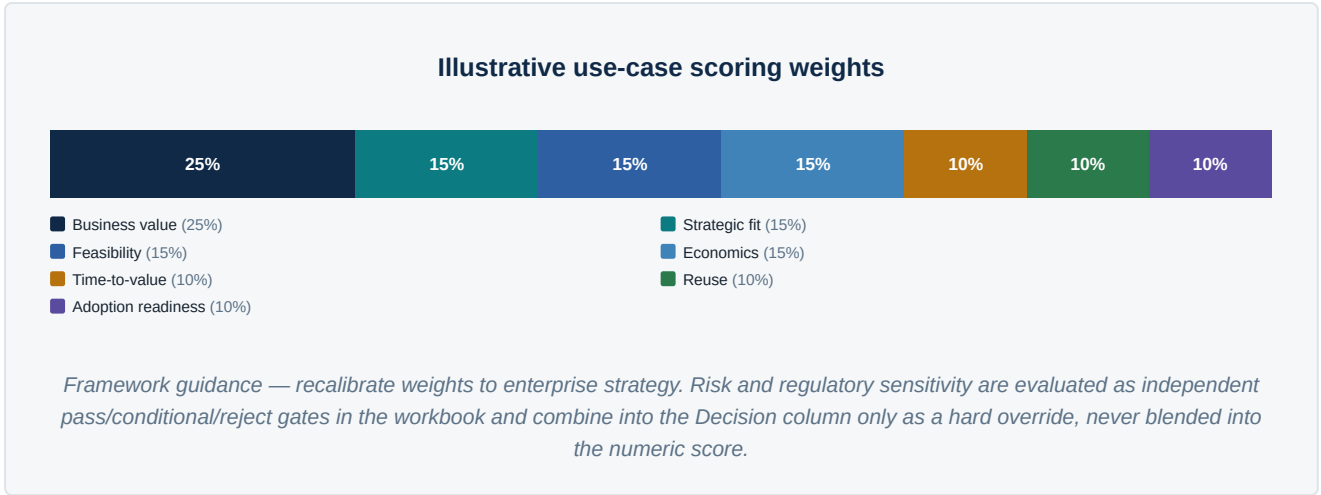
Figure 5.1. AI use-case funnel.



No AI project should bypass value, feasibility, risk and production-readiness gates.

Illustrative portfolio scoring

Treat high risk and regulatory sensitivity as separate gates, not weighted score components — see the corrected scoring model and worked examples in the companion workbook’s Use Case Portfolio sheet, which this figure mirrors exactly.



Cross-reference: complete the AI Business Case (Chapter 6) for any candidate scoring above the prioritization threshold before it is funded into a PoC.

6

PART I — STRATEGY & PORTFOLIO

AI Business Case & Benefits Realization

A use case that scores well on the portfolio matrix still needs a funded, falsifiable business case — and a mechanism that tracks whether the promised benefit actually shows up.

Three failure modes recur in enterprise AI business cases: benefits are estimated once at approval and never re-measured; AI run-cost (inference, platform allocation, human-review overhead) is omitted from the cost side; and "soft" benefits (productivity, quality) are claimed without a conversion method to dollars. The business case template below, reproduced fillable in Appendix L and live in the companion workbook's *Business Case* sheet, addresses all three.

Line item	Definition
One-time investment	Build, integration, data preparation, change management, initial evaluation-set creation
Annual run cost	Inference/token spend, platform allocation, human-in-the-loop review time, licenses, monitoring
Annual benefit	Revenue, cost avoidance, risk avoidance, productivity gain — each with a named evidence source
Payback period	One-time investment ÷ (annual benefit – annual run cost), in months
3-year ROI	((annual benefit – annual run cost) × 3 – one-time investment) ÷ one-time investment

Benefit categories and evidence discipline

Category	Evidence method	Typical confidence
Revenue growth	Attributable, time-boxed A/B or holdout comparison	High
Cost avoidance	Time-to-complete reduction × fully-loaded hourly cost, measured pre/post	High
Risk avoidance	Reduction in loss events / compliance escalations, historical baseline	Medium — inherently probabilistic
Productivity gain	Hours redeployed to higher-value work, validated by manager attestation or time-tracking	Medium — requires redeployment evidence, not just time saved

EVIDENCE RULE

A productivity claim without a redeployment story is not a benefit — it is unused slack. If a workflow gets 20% faster and nothing changes about headcount, backlog, or output, the business case should book zero benefit for that line until redeployment is evidenced.

Benefits realization tracking

Approve the business case once; track it quarterly. The companion workbook's Business Case sheet includes a quarterly Target vs. Realized tracker with automatic Red/Amber/Green coloring at <80% / 80–99% / ≥100% of the quarter's target — the same convention used on the Executive Dashboard in Chapter 23, so a use case's benefit realization status rolls up cleanly into portfolio-level reporting.

- ◆ Re-baseline the business case at the Pilot → Production gate using pilot-period actuals, not the original PoC estimate.
- ◆ Assign the benefits-realization owner at approval time — normally the business sponsor, not the delivery team.
- ◆ Report realization percentage alongside spend on the Executive Dashboard; a use case funded above budget with <80% realization is a candidate for the kill list in Chapter 5's funnel.
- ◆ Sunset review: any use case below 60% realization for two consecutive quarters triggers a mandatory continue/redesign/kill decision at the AI Steering Committee.

7

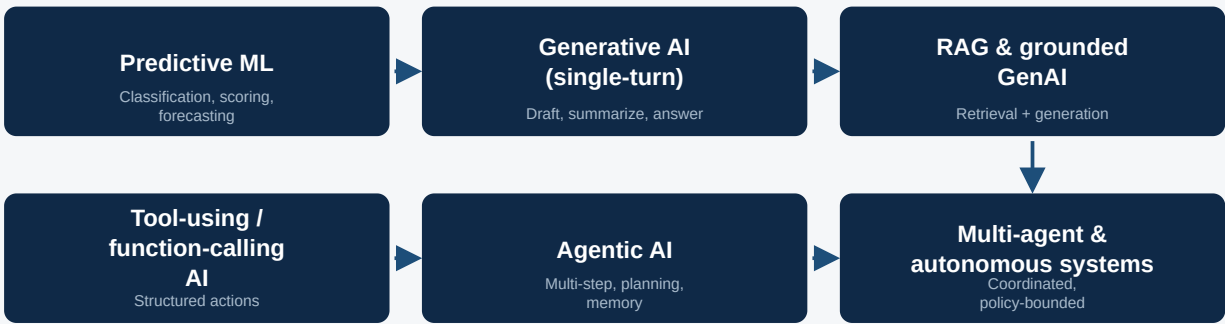
PART II — ENTERPRISE AI ARCHITECTURE

AI Technology Evolution

Architecture decisions age. A target architecture set for 2023-era retrieval-augmented generation will under-serve a 2026 agentic workload, and over-engineering for autonomy the enterprise cannot yet govern is equally costly.

Six overlapping technology waves are relevant to enterprise decisions today. They did not replace one another cleanly — most enterprises run production systems from three or four waves simultaneously — but each wave changed which architectural dimensions dominate design choices.

Figure 7.1. AI technology evolution — overlapping waves, not a replacement sequence.



Most enterprises operate systems from three or more waves concurrently; the architecture (Chapter 8) must accommodate all of them under one control plane, not just the newest.

Wave	Dominant architectural concern	Risk posture
Predictive ML	Model versioning, feature stores, drift monitoring	Established MLOps practice — lowest architectural risk
Generative AI (single-turn)	Prompt/config versioning, output validation	Moderate — content risk, low system risk
RAG & grounded GenAI	Retrieval authorization, provenance, freshness	Moderate-high — data-access risk dominates
Tool-using / function-calling	Schema validation, scoped credentials	High — action risk enters the picture
Agentic AI	Planning traces, budgets, approval gates, kill switch	High — autonomy risk, see Chapter 11
Multi-agent & autonomous systems	Delegation controls, inter-agent isolation, continuous evaluation	Highest — compounding autonomy and coordination risk

ARCHITECTURE PRINCIPLE

Do not select an architecture wave based on vendor marketing cadence. Select it based on the task: a well-specified classification problem is still best served by predictive ML in 2026, and adding a multi-agent layer to it adds cost, latency and failure surface without adding value.

8

PART II — ENTERPRISE AI ARCHITECTURE

Enterprise AI Reference Architecture (Logical View)

Eight logical layers, with a cross-cutting control plane governing every layer above it. This is the logical view; Chapter 9 develops the physical/infrastructure view that implements it, and Chapter 12 develops the platform engineering view that operates it.

Figure 8.1. Enterprise AI reference stack — logical view.



The control plane is not a layer to bolt on later — it is the mechanism that makes every other layer auditable and safe to scale.

- ◆ Use model/provider abstraction where justified.
- ◆ Enforce policy at model/API and agent/tool boundaries.
- ◆ Give every user, service, agent and tool call attributable identity.
- ◆ Make retrieval authorization-aware and provenance-aware.
- ◆ Version models, prompts, datasets, retrieval, tools and policies.
- ◆ Design for fallback and graceful degradation.
- ◆ Instrument quality, latency, security, tokens/cost and business outcomes.

See Chapter 9 for the physical/technology architecture that implements this stack, and Chapter 12 for the platform engineering blueprint that operates it day to day.

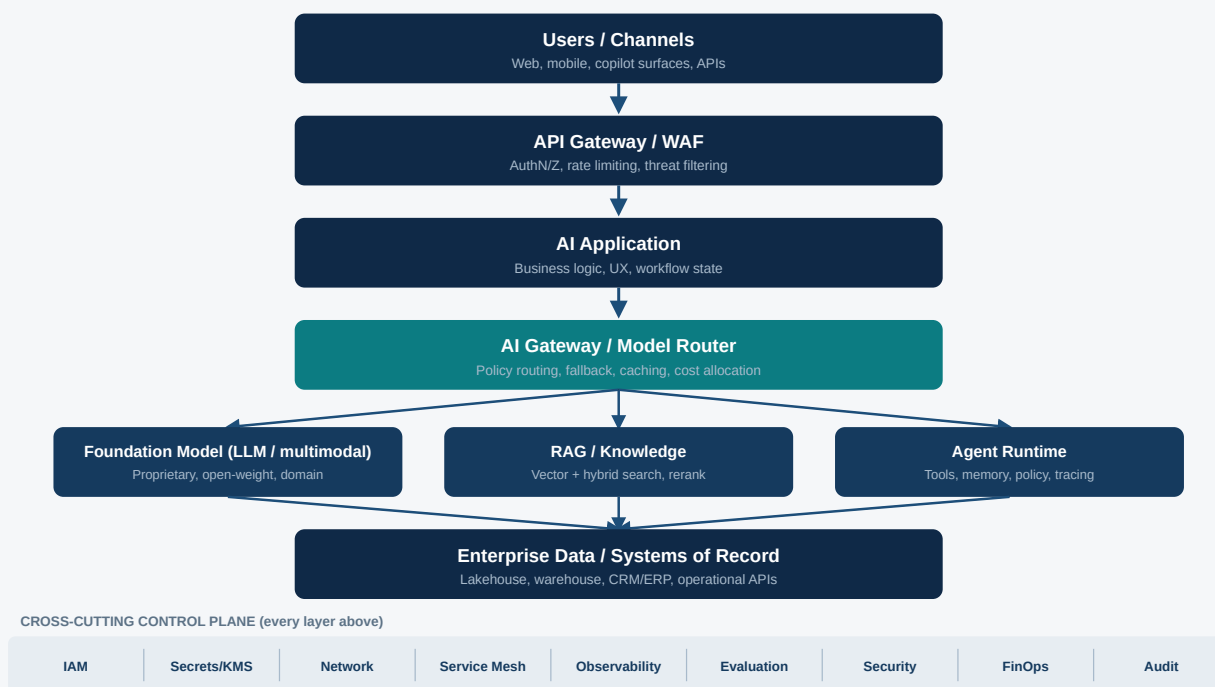
9

PART II — ENTERPRISE AI ARCHITECTURE

AI Infrastructure Architecture

The logical architecture in Chapter 8 says nothing about where compute runs, how models are served, or what happens when a region fails. This chapter makes those decisions explicit.

Figure 9.1. Physical / technology architecture — request path and cross-cutting control plane.



Every layer in the request path sits above a single cross-cutting control plane (identity, secrets, network, observability, evaluation, security, FinOps, audit) rather than each layer implementing its own version of these controls.

Compute & serving decisions

Decision	Options	Primary driver
Accelerator choice	GPU (training/high-throughput inference), TPU (large-scale training), NPU (edge/on-device inference)	Workload shape, provider availability, cost/throughput, portability
Serving pattern	Managed API, dedicated/reserved capacity, self-hosted inference server	Volume, latency SLO, data residency, cost at scale
Quantization	FP16/BF16 baseline, INT8/INT4 for cost-sensitive serving	Quality tolerance vs. cost/latency; always re-evaluate quality post-quantization

Decision	Options	Primary driver
Batching	Dynamic/continuous batching for throughput-bound workloads	Increases throughput, can increase tail latency — set explicit SLOs
Caching	Prompt/response caching, KV-cache reuse, semantic caching	Repeated/similar queries; correctness-sensitive tasks need cache-invalidation discipline

Build / host / consume decision spectrum

Figure 9.2. Infrastructure control spectrum.



Move right only when volume, data residency, cost at scale, or portability requirements justify the added operational burden — see the Build/Buy/Partner scorecard in Chapter 21 and Appendix K.

Resilience & disaster recovery

AI infrastructure needs the same resilience discipline as any tier-1 system, plus AI-specific failure modes: a single model provider outage, a degraded model version silently shipped by a provider, or a poisoned/stale knowledge index. The companion workbook's *Resilience & DR* sheet and Appendix P operationalize the matrix below.

Failure mode	Primary control	Recovery target
Model/provider outage	Multi-provider fallback routing at the AI gateway	RTO in minutes, degraded-mode SLA disclosed to users
Model quality regression (silent provider update)	Pinned model versions where offered; regression-suite gate before accepting new default versions	Detected within one evaluation cycle, not by user complaint
Knowledge index corruption / staleness	Point-in-time index snapshots, freshness SLO monitoring	Restore from last-known-good snapshot within RTO
Region/zone failure	Multi-region deployment for tier-1 AI applications; documented degraded mode for others	RTO/RPO tiered by business criticality, matching the enterprise DR policy
Runaway cost event	Hard spend circuit-breakers at the AI gateway, not just alerting	Automatic throttling within minutes of budget breach

RESILIENCE RULE

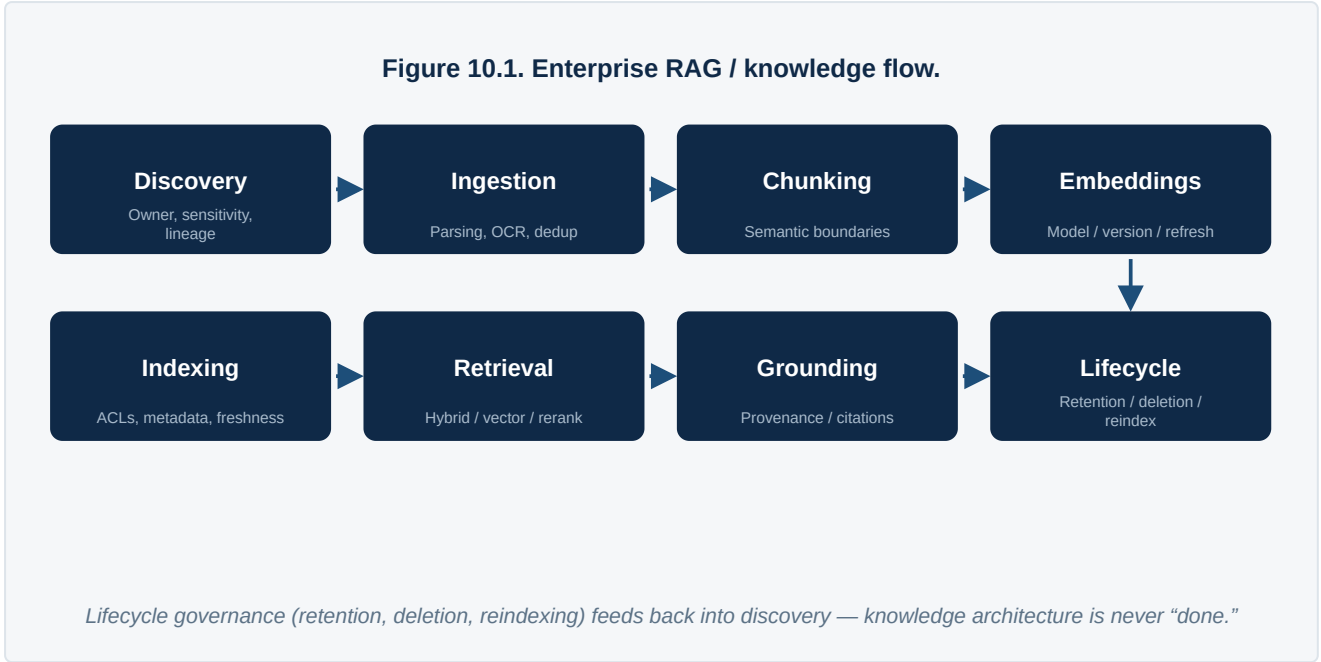
A multi-provider fallback that has never been tested is not a control — it is an assumption. Test model-provider failover at least quarterly, on the same cadence as other tier-1 DR exercises.

10

PART II — ENTERPRISE AI ARCHITECTURE

Data Foundation & Knowledge Architecture

Enterprise-grade retrieval-augmented generation (RAG) is a lifecycle of eight disciplines, not a single indexing step.



Capability	Controls	Artifacts
Data discovery	Owner, sensitivity, lineage	Inventory
Ingestion	Parsing, OCR, deduplication	Pipeline specification
Chunking	Semantic boundaries, metadata	Chunking standard
Embeddings	Model / version / refresh	Embedding registry
Indexing	ACLs, metadata, freshness	Index design
Retrieval	Hybrid / vector / rerank	Retrieval eval set
Grounding	Provenance / citations	Grounding policy
Lifecycle	Retention / deletion / reindexing	Lifecycle policy

ARCHITECTURE RULE

RAG is not a correctness guarantee. Enterprise RAG requires authorization-aware retrieval, provenance, freshness, retrieval evaluation and output validation.

Enterprise data engineering depth

Knowledge architecture inherits every pre-existing data-engineering weakness in the enterprise; AI does not fix data quality problems, it exposes them at higher velocity and to a wider audience. Four practices most directly determine whether RAG output can be trusted:

- ◆ **Data contracts** between source systems and the knowledge layer, specifying schema, freshness SLA and breaking-change notice — without these, embeddings silently drift out of sync with source-of-truth systems.
- ◆ **Lineage & provenance** tracked from source document through chunk through embedding to generated answer, so a disputed answer can be traced back to the exact source passage and its authorization scope.
- ◆ **Quality gates on ingestion** — reject or quarantine documents that fail parsing, contain conflicting versions of the same fact, or lack an identifiable owner, rather than indexing everything and hoping retrieval ranks around the noise.
- ◆ **Access-control synchronization** between the source system's permission model and the index's ACL metadata, re-synchronized on a bounded schedule so a revoked permission cannot surface stale content through retrieval.

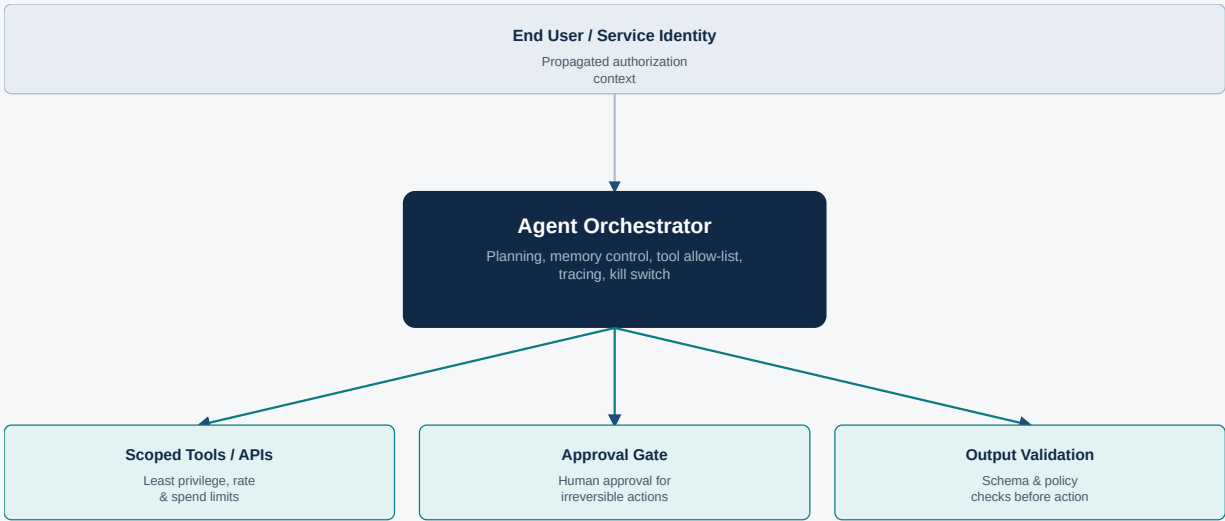
11

PART II — ENTERPRISE AI ARCHITECTURE

Generative AI, Agents & Agentic AI

Microsoft's 2026 AI-agent guidance describes agents as programs using generative models to interpret inputs, reason, retrieve context and take actions through tools; its adoption guidance covers planning, governance/security, building and management [R6].

Figure 11.1. Enterprise agent reference pattern.



Agent identity is distinct from end-user identity; every tool call, approval and output is traced and independently validated.

Figure 11.2. Agent autonomy & control ladder.



Controls escalate with autonomy: A0-A1 rely on content controls and human judgment; A3-A4 require policy budgets, delegation controls and continuous evaluation.

Tier	Behavior	Controls
A0 Assist	Generate/answer	Content controls, logging
A1 Recommend	Suggest action	Human approval
A2 Execute with approval	Act after approval	Least privilege + approval + audit

Tier	Behavior	Controls
A3 Bounded autonomy	Act within limits	Policy, budgets, rollback
A4 Multi-agent autonomy	Coordinate agents/tools	Delegation controls, isolation, continuous eval

- ◆ Separate agent identity from end-user identity and propagate authorization context.
- ◆ Use explicit tool allow-lists and schema validation.
- ◆ Set transaction, monetary, data-access and rate limits.
- ◆ Require approval for irreversible / high-impact actions.
- ◆ Control memory / state retention.
- ◆ Validate tool results and final outputs.
- ◆ Trace plans, tool calls, retries and actions.
- ◆ Provide kill switch and safe fallback.
- ◆ Evaluate goal success, tool correctness, policy adherence, unnecessary actions and cost.

MCP is relevant to standardized model-to-tool/context integration; A2A is relevant to agent-to-agent interoperability. Neither replaces enterprise identity, authorization, governance or API management.

Agent architecture patterns

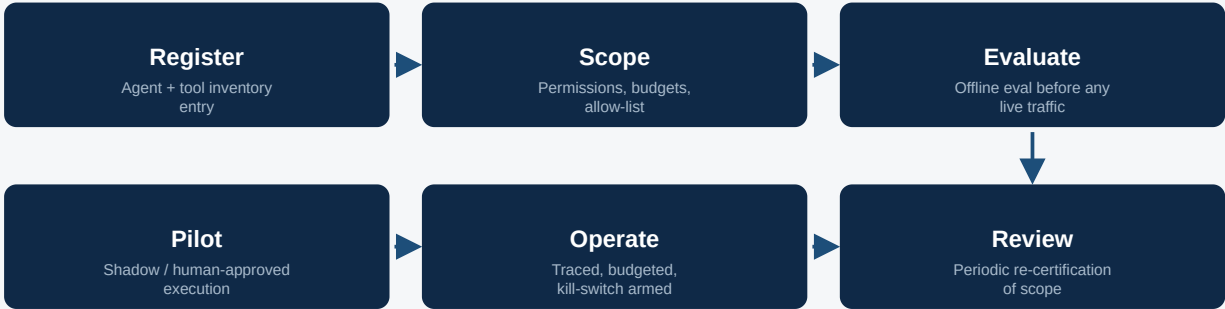
Single-agent, tool-using One orchestrator, a fixed tool allow-list, no delegation. Lowest complexity, easiest to audit. DEFAULT STARTING PATTERN	Planner-executor A planning agent decomposes a goal into steps; a separate executor agent (or deterministic runner) carries out each step under tighter permissions than the planner holds. SEPARATES JUDGEMENT FROM ACTION-TAKING AUTHORITY	Supervisor-worker A supervisor agent routes sub-tasks to specialized worker agents (e.g. retrieval worker, drafting worker, validation worker) and consolidates results. TASK SPECIALIZATION AT BOUNDED AUTONOMY
Multi-agent negotiation Multiple agents with distinct goals or data access negotiate or coordinate toward a shared outcome, each independently sandboxed. HIGHEST COMPLEXITY — A4 TIER ONLY	Human-in-the-loop co-pilot Agent proposes; a human approves each irreversible step before it executes. No autonomous action without sign-off. DEFAULT FOR HIGH RISK-TIER WORKLOADS	

Agent state & memory types

State type	Description	Governance requirement
Working memory	Current task context, cleared per session	Session-scoped, never persisted without explicit retention policy
Episodic memory	Record of past interactions/outcomes for this user or case	Retention policy required; subject to the same data-lifecycle rules as any personal data

State type	Description	Governance requirement
Semantic / long-term memory	Learned facts or preferences persisted across sessions	Highest governance burden — requires explicit consent and drift/staleness controls
Tool state	Credentials, session tokens, in-flight transaction state	Scoped, short-lived, never logged in plaintext

Figure 11.3. Agent lifecycle — from registration to periodic re-certification.



An agent's tool scope is re-certified on a fixed cadence (Appendix E / Appendix N), not granted once and forgotten.

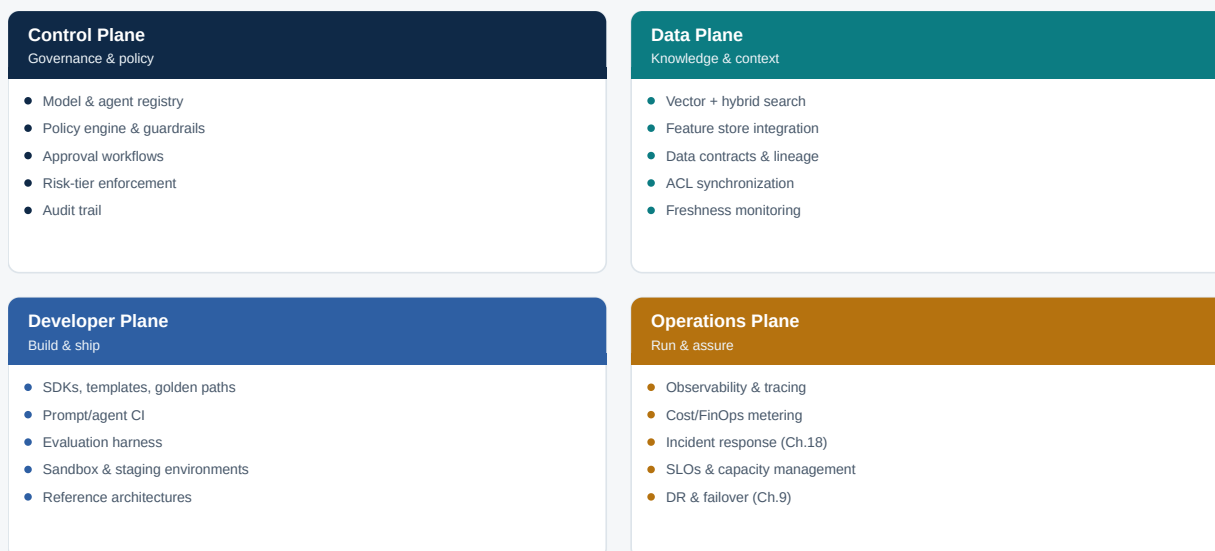
12

PART III — AI PLATFORM & ENGINEERING

Enterprise AI Platform Blueprint

Chapter 8 described the logical architecture and Chapter 9 the physical infrastructure. This chapter describes the platform organized as four operational planes — the way a platform team actually staffs, roadmaps and runs it.

Figure 12.1. Enterprise AI platform blueprint — four operational planes.



Each plane maps to a distinct on-call rotation and roadmap owner in the operating model (Chapter 19); the planes share one control plane so that policy, budget and audit posture stay consistent across every AI application built on the platform.

Plane ownership and interfaces

Plane	Primary owner	Produces	Consumption rule
Control Plane	AI Platform / CoE	Registry entries, policy decisions, approval records	Read by every plane; write access restricted to platform + risk/security
Data Plane	AI Platform + Data Engineering	Indexed, ACL-synced, freshness-monitored knowledge	Consumed by Developer Plane via retrieval APIs, never direct index access
Developer Plane	AI Platform Engineering	SDKs, CI pipelines, evaluation gates	Domain product teams build against this plane's golden paths
Operations Plane	AI Platform SRE	Dashboards, alerts, incident runbooks, cost reports	Feeds the Executive Dashboard (Ch.23) and FinOps ledger (Ch.20)

PLATFORM FUNDING RULE

A platform team that builds all four planes as one undifferentiated backlog will always under-invest in Operations, because control- and developer-plane features are more visible to sponsors. Fund and roadmap the four planes separately, with the Operations Plane held to the same SLO discipline as any production system it supports.

13

PART III — AI PLATFORM & ENGINEERING

Models & Vendor Strategy

Select models per workload, not by a single enterprise leaderboard. Evaluate capability, safety, latency, context, modality, data controls, residency, tool use, reliability, customization and total cost.

Frontier proprietary

OpenAI, Anthropic, Google.

Selection lens: capability, controls, latency, pricing, terms.

GENERAL & COMPLEX REASONING

Cloud AI platforms

AWS Bedrock, Azure AI Foundry, Google Vertex AI. *Selection lens:* model choice, networking, governance, integration.

ENTERPRISE INTEGRATION

Open-weight

Meta, Mistral and others. *Selection lens:* license, hosting, performance, customization.

COST & DATA CONTROL

Enterprise data / AI

Databricks, Snowflake and others.

Selection lens: data integration, governance, lifecycle.

DATA-NATIVE WORKLOADS

Evaluation / observability

Langfuse, Arize Phoenix, MLflow, LangSmith, W&B Weave and others. *Selection lens:* tracing, evals, datasets, integrations.

QUALITY ENGINEERING

AI security

Cloud-native and specialist vendors.

Selection lens: runtime protection, posture, red team, policy.

THREAT COVERAGE

Infrastructure

NVIDIA, AMD, cloud accelerators/providers. *Selection lens:* throughput, latency, utilization, portability.

UNIT ECONOMICS

PROCUREMENT RULE

Do not choose a model solely from a public benchmark. Require task-specific evaluation using representative enterprise data, production-like latency, safety/security tests, tool-use tests and economics.

Model selection matrix

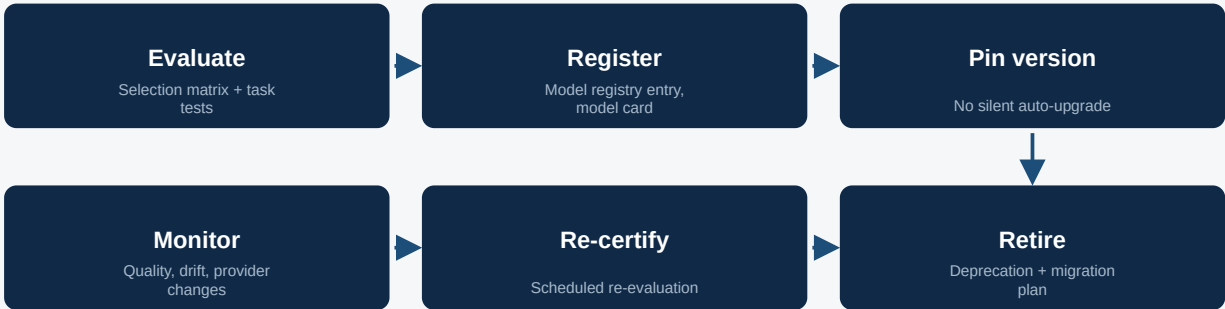
Score each candidate model 1–5 against ten weighted dimensions; the companion workbook's *Model Selection Matrix* sheet (and the fillable version in Appendix J) automates the weighted total and includes a weight-check that must sum to 100%.

Dimension	Illustrative weight	Notes
Task-specific quality	20%	Evaluated on representative enterprise data, not public leaderboards
Reasoning	10%	Multi-step / complex-instruction tasks relevant to the workload
Tool calling	10%	Reliability of structured function/tool invocation
Latency	10%	p50/p95 under production-like load
Cost	15%	Blended input/output/tool cost at expected volume

Dimension	Illustrative weight	Notes
Security / data controls	10%	Data handling, retention, training-use terms
Data residency controls	10%	Regional processing/storage guarantees
Context window	5%	Sufficient for the retrieval/agent design
Multimodal support	5%	Only weighted if the workload requires it
Portability / exit	5%	Switching cost if the provider relationship ends

Model lifecycle

Figure 13.1. Model lifecycle — from evaluation to retirement.



A model that passes evaluation and is registered still gets re-certified on a schedule — provider-side model updates are a change event, not a non-event.

14

PART III — AI PLATFORM & ENGINEERING

AI Platform Engineering & GenAIOps

Nine platform services move from MVP to mature capability as the portfolio scales:

Platform service	MVP	Mature
Model gateway	Auth, routing, quotas	Policy routing, fallback, caching, allocation
Prompt/config registry	Versioning	Approval, A/B, lineage
Evaluation	Offline runner	Continuous regression / production evals
Observability	Trace + latency	Tool / retrieval / cost / quality traces
Knowledge	Ingestion + search	ACL-aware, freshness, optimization
Agent runtime	Tool calling	Policy, delegation, budgets, state
Security	IAM, secrets, network	AI threat detection / runtime policy
FinOps	Spend report	Unit economics + optimization
Developer portal	Reference patterns	Golden paths / self-service

GenAIOps delivery lifecycle

Figure 14.1. GenAIOps delivery lifecycle.



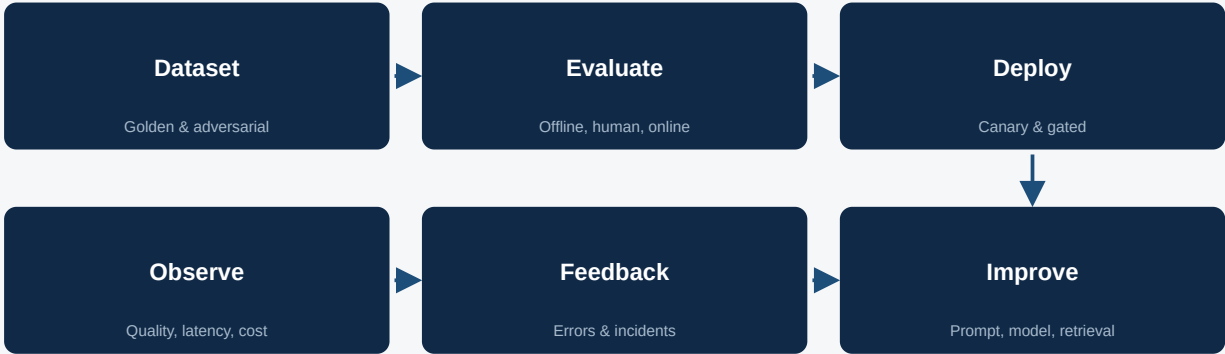
Nine steps, run per release — the evaluation dataset is created before major implementation, not after.

15

PART III — AI PLATFORM & ENGINEERING

AI Evaluation, Quality Engineering & Observability

Figure 15.1. AI evaluation and observability loop.



Treat evaluation as continuous quality engineering, not a pre-launch checkbox.

Dimension	Metrics
Correctness	Task accuracy, rubric score
Grounding	Faithfulness, citation correctness, context precision/recall
Safety	Policy violations, jailbreak resistance
Security	Prompt injection / data exfiltration resistance
Agent behavior	Goal success, tool correctness, unnecessary actions
Reliability	Errors, timeouts, fallbacks
Performance	p50 / p95 / p99 latency, throughput
Economics	Cost/request, tokens/task, cost/task
Human outcome	Acceptance, edit, escalation, CSAT
Business value	Revenue, savings, risk, cycle time

- ◆ Unit tests for parsing, retrieval filters, authorization and tool schemas.
- ◆ Golden-set regression for prompts/model/retrieval changes.
- ◆ Model-graded evaluation with calibrated rubrics; do not rely on one judge.
- ◆ Adversarial / security tests; use OWASP GenAI guidance [R4][R5].
- ◆ Human evaluation for high-impact / subjective tasks.

- ◆ Production monitoring with drift and feedback.

Evaluation operating model

Evaluation is a shared platform service (Chapter 12, Developer Plane), not a one-off activity owned by whichever team builds a given use case. Three roles keep it running as a discipline rather than a checklist:

Role	Responsibility
Evaluation Lead (platform)	Owns the evaluation harness, judge calibration, and the golden-dataset standard used enterprise-wide
Domain Evaluation Owner	Owns the golden/adversarial dataset for a specific use case and signs off release gates for it
Independent Reviewer	For High/Critical risk-tier systems, reviews evaluation results independently of the delivery team before production release

EVALUATION INDEPENDENCE RULE

A team that writes its own evaluation set, runs its own evaluation, and signs its own release gate has no independent check on optimism. Require an evaluation owner distinct from the delivery lead for any Moderate-or-above risk-tier system, and an independent reviewer for High/Critical.

16

PART IV — RISK, SECURITY & COMPLIANCE

Responsible AI, Governance, Risk & Compliance

NIST AI RMF provides a risk-management structure for organizations designing, deploying or using AI; its Generative AI Profile identifies risks and actions across the lifecycle [R1][R2]. ISO/IEC 42001 specifies requirements for establishing and continually improving an AI Management System [R3].

Control	Requirement	Evidence
Inventory	Every AI system registered	AI system register
Risk	Impact, autonomy, data sensitivity	Risk assessment
Data	Purpose, lineage, retention, access	Data assessment
Model	Version, approval, model card	Model registry
Evaluation	Pre-prod + production tests	Eval reports
Security	Threat model, red team, IAM	Security assessment
Privacy	Minimization, residency, retention	Privacy assessment
Legal / IP	Licensing, copyright, contracts	Legal review
Human oversight	Approval / escalation	HITL procedure
Incident	AI-specific incident response	Incident records
Audit	Traceability	Audit logs

Tier	Posture	Approval
Low LOW	Low consequence / internal productivity	Product + standard controls
Moderate MODERATE	Business recommendation	Product + security/risk
High HIGH	Material / customer / regulated decision or action	Formal risk/legal + executive owner
Critical / Prohibited CRITICAL	Outside policy / unacceptable risk	Do not deploy

REGULATORY NOTE

Regulatory applicability depends on jurisdiction and use case. Privacy, employment, financial-sector and contractual obligations may add requirements; this framework does not replace legal advice.

EU AI Act — 2026 update. Under the "Digital Omnibus" agreement reached in 2026, compliance deadlines for high-risk AI systems have been postponed: stand-alone high-risk systems under Annex III now must comply by **2 December 2027** (previously August 2026), and AI embedded in regulated products under Annex I moves to **2 August 2028** (previously August 2027) [R12]. General-purpose AI model obligations and prohibited-practice provisions that already took effect are unaffected. Treat this as a deferred deadline, not a cancelled one, and confirm current status before finalizing compliance plans.

Control lifecycle

Governance controls decay if treated as a one-time approval. Run every control in the table above through a four-stage lifecycle:

Figure 16.1. Control lifecycle — every governance control is re-certified, not approved once.



A control with no re-certification date is a control that will silently stop being true as the system, data or provider changes underneath it.

17

PART IV — RISK, SECURITY & COMPLIANCE

AI Cybersecurity Architecture

Prompt injection Malicious instructions. <i>Controls:</i> Isolation, provenance, instruction hierarchy	Data leakage Sensitive context exposed. <i>Controls:</i> DLP, ACL-aware retrieval, minimization	Tool abuse Unauthorized API calls. <i>Controls:</i> Allow-list, scoped credentials, policy
Supply chain Compromised package/model/data. <i>Controls:</i> SBOM, provenance, scanning	Model abuse Jailbreak / unsafe output. <i>Controls:</i> Safety filters, adversarial tests	Excessive agency Unbounded actions. <i>Controls:</i> Budgets, approvals, least privilege
Unbounded consumption Loops / cost attacks. <i>Controls:</i> Quotas, budgets, rate limits	Vector risks Poisoned / unauthorized knowledge. <i>Controls:</i> ACLs, provenance, validation	Prompt leakage Sensitive instructions exposed. <i>Controls:</i> No secrets in prompts, boundary controls
Telemetry leakage Sensitive prompts in logs. <i>Controls:</i> Redaction, retention, access		

OWASP's 2025 material highlighted unbounded consumption, vector/embedding risks, system prompt leakage and excessive agency [R5]. OWASP's current 2026 GenAI/LLM Top 10 was published **3 August 2026** [R4] and again ranks prompt injection and sensitive information disclosure at the top, with excessive agency and unbounded consumption climbing the ranking on incident evidence.

AI-specific security reference architecture

The cross-cutting control band in the physical architecture (Chapter 9, Figure 9.1) is where these threats are actually countered. Four control points map directly onto that band:

Control point (Fig. 9)	Threats addressed	Primary controls
AI Gateway / Model Router	Prompt injection, unbounded consumption	Instruction-hierarchy enforcement, per-identity rate & spend limits, response filtering
Agent Runtime boundary	Excessive agency, tool abuse	Scoped credentials, tool allow-lists, approval gates for irreversible actions
RAG / Knowledge boundary	Vector/embedding risks, data leakage	ACL-aware retrieval, provenance tagging, poisoning detection on ingestion
Observability & Audit plane	Prompt/telemetry leakage, forensic gap	Redaction before storage, restricted access to raw traces, immutable audit trail

SECURITY INTEGRATION RULE

Security architecture for AI is not a separate program from application security — it is application security extended to two new trust boundaries: the model/prompt boundary and the tool/action boundary. Route AI-specific findings through the same vulnerability-management process as every other system, tagged distinctly for trend reporting.

18

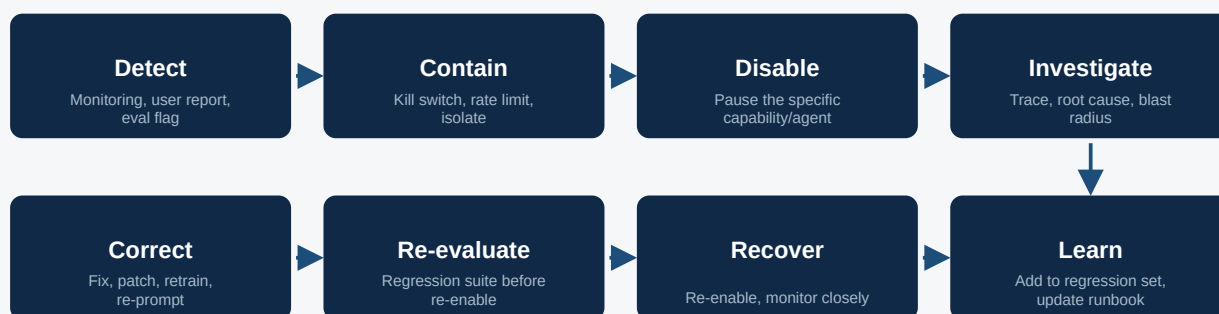
PART IV — RISK, SECURITY & COMPLIANCE

AI Incident Management

An AI incident is not always a security breach. A model that confidently hallucinates a contract term, an agent that takes an unintended action within its granted permissions, or a bias finding in production output are all AI incidents requiring a defined response — most with no analog in traditional IT incident management.

Incident class	Example	Primary owner
Content/quality incident	Hallucination, factual error, harmful or biased output reaching a user	Business/Product Owner
Security incident	Prompt injection, data exfiltration, unauthorized tool use	CISO / Security Incident Response
Autonomy incident	Agent acts outside intended scope, even within granted permissions	AI Platform + Business Owner
Availability incident	Provider outage, latency SLO breach, cascading fallback failure	AI Platform SRE
Compliance incident	Output or action breaches a regulatory or contractual obligation	Risk / Legal / Compliance

Figure 18.1. AI incident response flow — Detect through Learn.



The distinguishing step versus standard IT incident response is **Re-evaluate**: an AI system is never returned to production after a fix without running it through the evaluation gates in Chapter 15, because a fix for one failure mode can silently introduce another.

Severity matrix

Severity	Definition	Response SLA	Badge
SEV-1	Active harm to customers, regulatory exposure, or uncontrolled agent action	Immediate kill switch; executive + legal notification within 1 hour	1
SEV-2	Material quality/security defect, contained but user-facing	Disable affected capability within 4 hours; incident lead assigned	2
SEV-3	Defect detected internally before user impact, or low-impact user-facing issue	Fix within the current sprint; logged to the regression set	3
SEV-4	Near-miss or evaluation-caught issue with no production exposure	Logged, reviewed at the next evaluation retrospective	4

CLOSURE RULE

Every SEV-1 and SEV-2 incident adds at least one case to the golden/adversarial evaluation dataset for the affected system (Chapter 15). An incident that does not change the regression suite has not actually been learned from — it can recur silently after the next model or prompt change.

Use the AI Incident Report template in Appendix N to record incidents in a structured, auditable form consistent with this taxonomy.

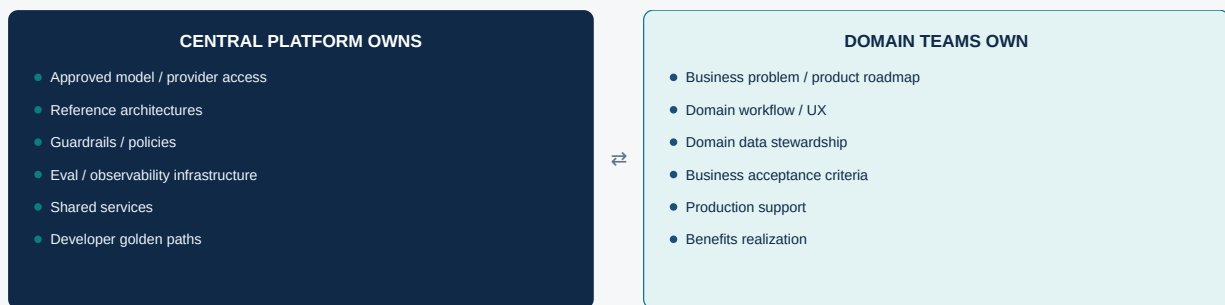
19

PART V — OPERATING MODEL & ECONOMICS

Operating Model & Organization Design

- ◆ **AI Council:** strategy, investment, policy and risk appetite.
- ◆ **AI Platform Engineering:** shared runtime, model access, evals, observability, security and developer experience.
- ◆ **AI CoE / Enablement:** standards, reference architectures, training and reusable assets.
- ◆ **Domain AI Product Teams:** product ownership, domain data, integrations, adoption and outcomes.
- ◆ **AI Risk & Assurance:** independent challenge, controls and audit.
- ◆ **AI FinOps / Value Office:** spend, unit economics, benefits and vendor economics.

Figure 19.1. Central platform vs. domain team ownership split.



Centralize what must be consistent and auditable; decentralize what must move at the speed of the business.

ORGANIZATION PRINCIPLE

Do not build a large isolated AI team by default. Build AI fluency into product, software, data, security, architecture and operations teams; concentrate scarce specialist skills in platform/CoE and high-value domains.

Team topology by maturity level

Team shape should track the maturity ladder in Chapter 3 — a Level-1 enterprise staffed like a Level-4 enterprise overspends on platform before it has portfolio scale to justify it, and the reverse under-invests once scale arrives.

Maturity level	Team shape	Illustrative sizing
0–1 · Unaware/Experimental	Small central team runs PoCs; no dedicated platform	2–5 FTE, often borrowed from data/engineering
2 · Repeatable	Platform team stood up; 1-2 domain teams onboarded	8–15 FTE across platform + first domain teams
3 · Scaled	Full four-plane platform team (Ch.12); 4+ domain teams self-serve	25–50+ FTE, platform:domain ratio roughly 1:3

Maturity level	Team shape	Illustrative sizing
4 · AI-Native	AI fluency embedded in every product team; platform team shifts to golden-path curation	Platform team stabilizes or shrinks; domain-embedded AI skill grows
5 · Adaptive	Platform team owns policy-driven autonomy controls; domain teams operate largely self-sufficiently	Specialist growth concentrates in risk/assurance and platform governance

Funding models

Model	Strength	Trade-off
Central-funded platform, chargeback for usage	Predictable platform investment; usage costs attributed fairly	Central subsidizes standards; domains pay only their marginal usage
Fully devolved (each domain funds its own AI)	Domains most closely feel cost/benefit trade-off	Duplicated platform investment, inconsistent controls — avoid past pilot scale
Central-funded through Scale, devolved at AI-Native	Front-loads platform investment when reuse value is highest	Requires an explicit, dated handover point in the roadmap (Chapter 22)
Benefit-share / value-based funding	Platform funded from a share of realized benefit (Chapter 6 tracker)	Aligns platform incentives to actual benefit realization, not just delivery volume

FUNDING RULE

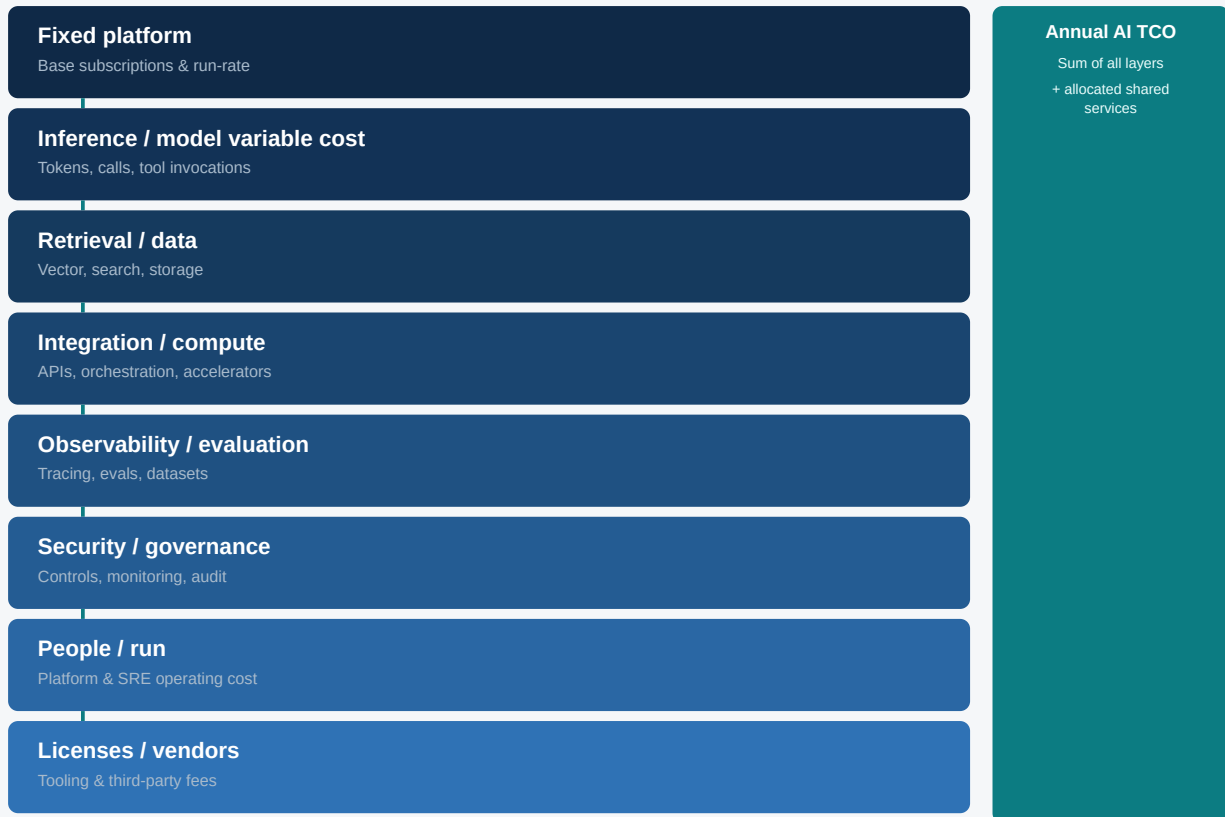
Most enterprises should start central-funded and set an explicit, calendar-dated trigger for shifting toward chargeback or devolved funding — for example, at the Scale gate in the roadmap (Chapter 22) — rather than leaving the funding model to drift.

20

PART V — OPERATING MODEL & ECONOMICS

AI Economics: TCO, Tokenomics & FinOps

Figure 20.1. AI TCO and token economics — cost composition.



Annual AI TCO = fixed platform + inference/model variable cost + retrieval/data + integration/compute + observability/evaluation + security/governance + people/run + licenses/vendors + allocated shared services.

Metric	Formula
Input token cost	Input tokens / 1M × input \$/MTok
Output token cost	Output tokens / 1M × output \$/MTok
Tool cost	Tool calls × cost/call or downstream cost
Cost/request	All request-level AI/platform variable cost
Cost/task	Total cost ÷ successfully completed task
Cost/outcome	Total cost ÷ accepted outcome
Gross AI value	Benefit generated – incremental AI cost
ROI	(Incremental benefit – incremental cost) ÷ incremental cost

FinOps Foundation identifies AI as a distinct cost/value scope because spending spans cloud, data centers, SaaS, AI vendors, neo-clouds and hyperscalers [R7][R8].

- ◆ Route simple work to efficient models and complex work to stronger models.
- ◆ Reduce prompt/context size and optimize retrieval.
- ◆ Use caching and batch processing where supported.
- ◆ Control output length and use structured outputs.
- ◆ Use semantic caching when correctness permits.
- ◆ Consider self-hosted / open-weight inference when utilization and operations justify it.
- ◆ Optimize accelerator placement and scheduling.
- ◆ Limit agent loops / tool calls.
- ◆ Allocate cost by product, business unit, environment and use case.

PRICING CURRENCY

Provider pricing changes frequently. Current OpenAI and Anthropic public pricing pages illustrate input/output, caching and batch economics as of August 2026; refresh live prices at procurement and business-case time [R9] [R10].

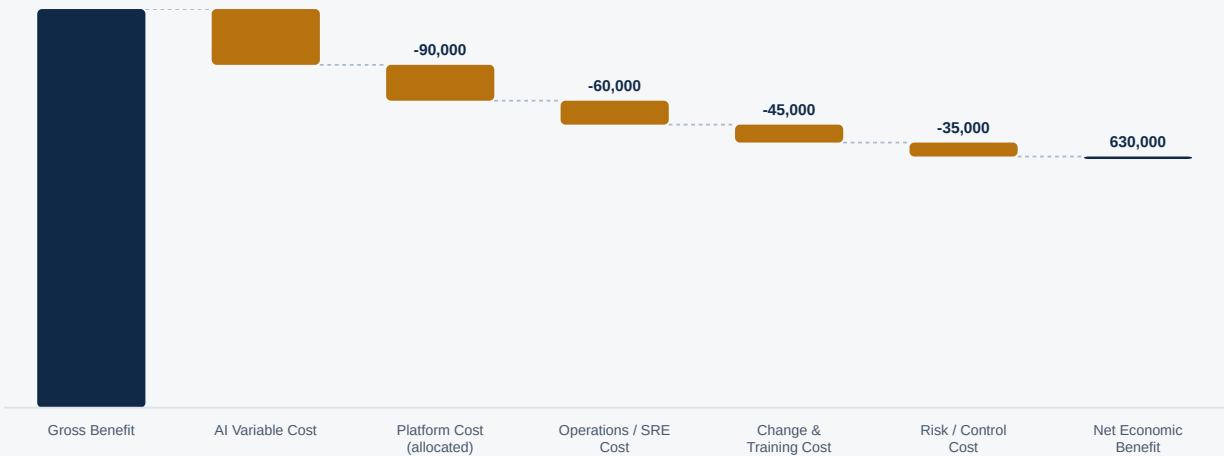
Three economic layers

AI economics is best analyzed as three layers, each with a different owner and a different failure mode if neglected. Chapter 6's business case operates the top layer; the TCO model above operates the middle; the bottom layer connects both to the enterprise financial ledger.

Layer	What it answers	Common failure if skipped
Value layer	Business benefit realized per Chapter 6's tracker	Benefit claimed but never re-measured against actuals
Unit-economics layer	Cost/task, cost/outcome per the metrics table above	Aggregate spend tracked, but no visibility into which use case drives it
Ledger layer	Allocation of AI spend to business units, cost centers and budgets	AI spend treated as one undifferentiated cloud line item

AI ROI waterfall

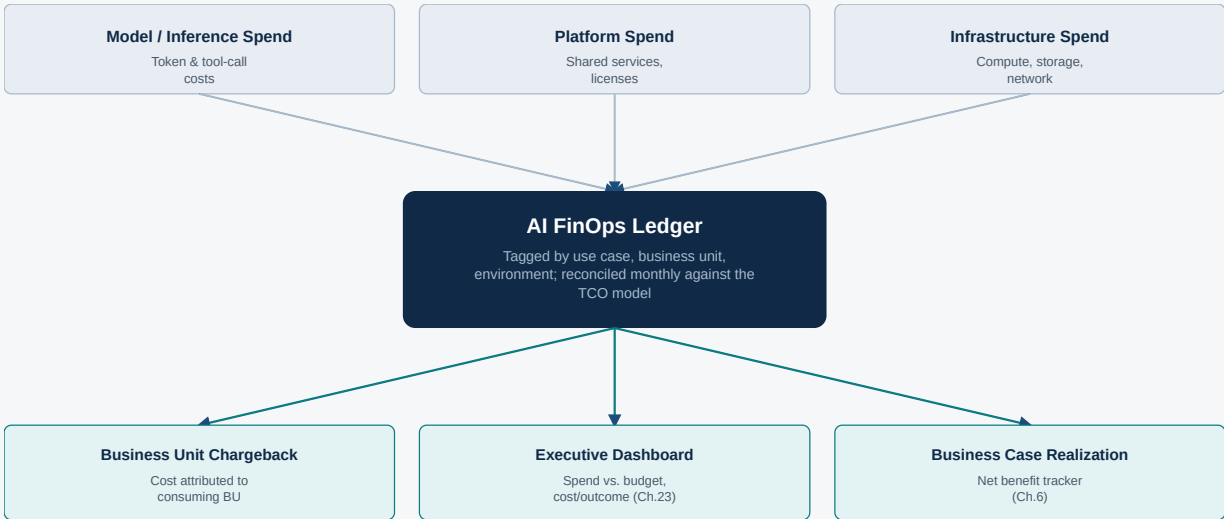
Figure 20.2. Illustrative AI ROI waterfall — gross benefit to net economic benefit.



Each deduction is a named cost layer from the table above, not a single blended 'AI cost' figure — this is what lets the FinOps team and the business sponsor agree on where value is actually being consumed.

AI cost architecture — money flow

Figure 20.3. AI cost architecture — money flow from spend to accountability.



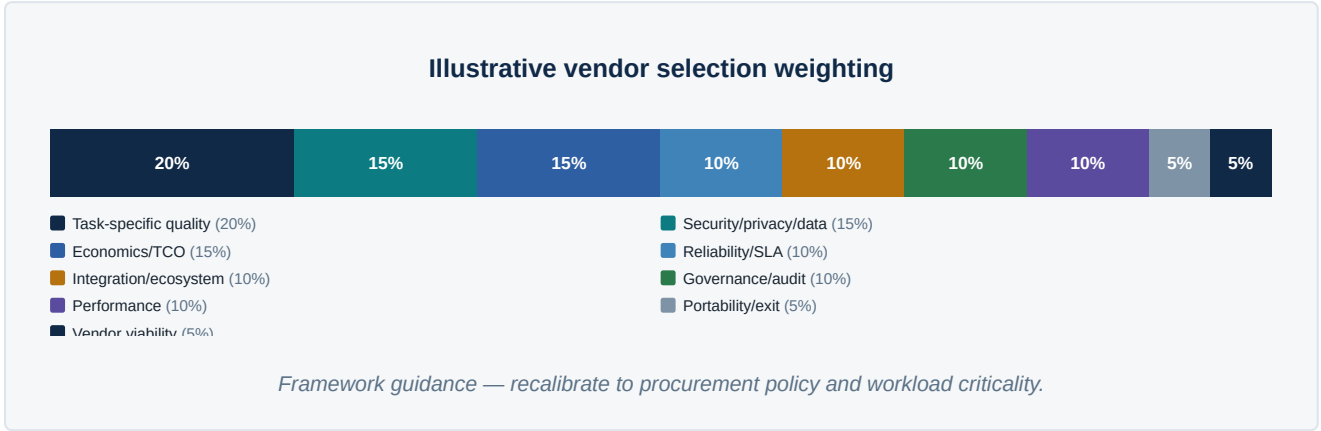
Every dollar of AI spend is tagged at source (use case, business unit, environment) so it can be reconciled against both the TCO model and the benefits-realization tracker without manual allocation.

21

PART V — OPERATING MODEL & ECONOMICS

Vendor & Procurement Strategy

Capability	Evaluate	Vendor categories
Foundation models	Quality, safety, latency, cost, data terms	Model providers
Cloud AI platform	Security, networking, integration	AWS / Azure / GCP
Search / vector	Hybrid search, ACLs, scale	Search / vector / database vendors
Agent runtime	Tools, state, policy, telemetry	Cloud / open-source / specialist
Evaluation	Datasets, judges, human review	AI eval platforms
Observability	Tracing, cost, latency, quality	LLM observability
Security	Threats, posture, runtime	AI security
Data platform	Governance, lineage, lakehouse	Data vendors
Infrastructure	Throughput, utilization, portability	GPU / accelerator / cloud



Build / Buy / Partner / Open-Weight decision matrix

Vendor selection (above) assumes the enterprise has already decided to acquire a capability externally. The prior question — build it, buy it as SaaS, configure a platform, partner, or self-host an open-weight alternative — deserves its own scored decision, reproduced live in the companion workbook's *Build-Buy-Partner* sheet and fillable in Appendix K.

Criterion	Question	Guidance
Differentiation	Does this capability differentiate the enterprise competitively?	Weighted most heavily toward Build/Open-Weight when the answer is yes
Speed to value	How quickly must this be in production?	Favors Buy/Configure for time-boxed commitments

Criterion	Question	Guidance
Cost at scale	What does the option cost at 10x today's volume, not today's volume?	Open-Weight/Build often wins at scale despite higher near-term cost
Control	How much control over behavior, data handling and roadmap is required?	Build/Open-Weight maximize control; Buy minimizes it
Portability / exit	What is the cost of switching away from this option in two years?	Build/Open-Weight score highest; single-vendor SaaS scores lowest
Internal skills required	Does the enterprise have, or plan to build, the skills to run this option?	A capability with no internal skill path should not default to Build

DECISION SCOPE RULE

Build/Buy/Partner is a per-capability decision, not an enterprise-wide policy. An enterprise can correctly buy its foundation-model access while building its own agent-orchestration layer and partnering for evaluation tooling — score each capability independently against the criteria above.

22

PART VI — DELIVERY & OVERSIGHT

Implementation Timeline & Roadmap

Figure 22.1. Typical roadmap — planning pattern, not a delivery benchmark.



These are planning ranges, not externally validated benchmarks. Data quality, regulatory review, security, legacy integration, procurement and organizational change can dominate elapsed time.

Phase	Planning range	Outputs	Gate
0 Mobilize	2–4 wks	Charter, baseline, sponsor	Funding / alignment
1 Strategy	4–8 wks	Strategy, portfolio, governance	Portfolio approved
2 Foundation	6–12 wks	Platform MVP, controls	Platform ready
3 PoC / Pilot	8–16 wks	2–5 production-shaped pilots	Value / quality / risk evidence
4 Industrialize	3–6 mo	Reusable platform + GenAIOps	Scale gate
5 Scale	6–12+ mo	Multiple domains / agents	Value realized
6 AI-native	12–24+ mo	AI embedded in operating model	Continuous optimization

Workstreams & dependencies

Ten workstreams run in parallel across the phases above. The roadmap slips when a downstream workstream is scheduled without checking that its dependency has actually cleared its own gate — not when any single workstream runs late in isolation.

Workstream	Key dependency	Framework ref.	Exit signal
1. Strategy & portfolio	—	Ch.1–6	Charter, prioritized backlog

Workstream	Key dependency	Framework ref.	Exit signal
2. Data foundation	Depends on: none (can start in parallel with #1)	Ch.10	Data contracts, first indexed domains
3. Platform engineering	Depends on: #1 (architecture principles)	Ch.9, 12, 14	Model gateway, eval harness, observability MVP
4. Governance & risk	Depends on: #1 (risk appetite set)	Ch.16	Risk-tiering method, control framework live
5. Security	Depends on: #3 (platform to secure)	Ch.17	Threat model, red-team baseline
6. Use-case delivery	Depends on: #2, #3, #4 minimally viable	Ch.5, 11	First 2–5 pilots in production-shaped form
7. Evaluation & quality	Depends on: #3 (harness), #6 (systems to evaluate)	Ch.15	Golden sets, regression gates operating
8. Economics & FinOps	Depends on: #3 (spend to meter)	Ch.20	TCO model live, cost tagged by use case
9. Operating model & skills	Depends on: #1 (target operating model agreed)	Ch.19, 24	Roles staffed, training curriculum live
10. Change & adoption	Depends on: #6 (something to adopt)	Ch.24	Adoption plan executed per pilot

SEQUENCING RULE

The most common roadmap failure is not any single workstream running late — it is sequencing #6 (use-case delivery) ahead of #2–#4 reaching minimum viability. A pilot built on ungoverned data with no evaluation harness is a liability, not an accelerant, however fast it ships.

23

PART VI — DELIVERY & OVERSIGHT

Executive Dashboards & KPIs

Dimension	KPIs
Portfolio	# use cases, stage mix, time-to-value, kill rate
Business value	Revenue, savings, risk reduction, cycle time
Adoption	Users, task adoption, acceptance/edit rate
Quality	Task success, grounding, safety, human rating
Reliability	Availability, p95 latency, failure/fallback
Security	Findings, incidents, policy violations
Governance	% inventoried/assessed, exceptions
Economics	Spend, cost/task, cost/outcome, forecast variance
Engineering	Lead time, deployment frequency, defects, reuse
Workforce	Skills, training, adoption

Figure 23.1. Illustrative executive AI dashboard — sample panel layout.



Ten panels: portfolio funnel; benefits vs. target; quality trend; risk heatmap; spend vs. budget; model mix; agent activity; adoption — populated from the platform's telemetry and the FinOps ledger, not manually assembled.

Three-tier audience model

One dashboard cannot serve the Board, the CIO/CDAO, and the platform team equally well — each needs a different grain and a different refresh cadence.

Audience	Refresh cadence	Primary content	Detail level
Board / Executive	Quarterly	Value realized vs. target, top risks, portfolio health at a glance	4–6 headline KPIs, no drill-down
CIO / CDAO / Steering Committee	Monthly	Portfolio funnel, spend vs. budget, quality/reliability trend, governance exceptions	10-panel mockup above; drill-down to domain level
AI Platform / Domain Teams	Real-time / daily	Per-system quality, latency, cost, incident status, evaluation results	Full observability stack; drill-down to individual trace

BUILD SEQUENCING RULE

Build the platform-team tier first — it is the source data for the other two. A Board dashboard built before the underlying telemetry exists becomes a manually-assembled slide deck that quietly diverges from reality within one quarter.

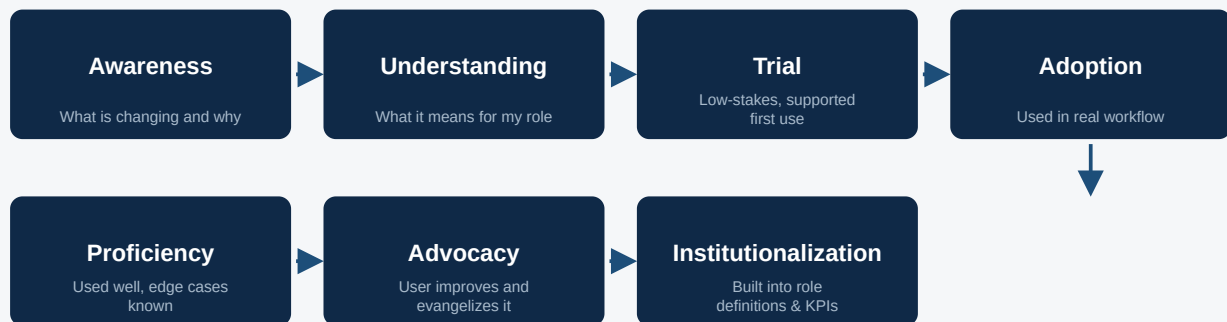
24

PART VI — DELIVERY & OVERSIGHT

Change Management & Adoption

AI adoption fails more often from unmanaged workforce change than from model quality. Treat adoption as a designed, measured process — not an assumed side-effect of shipping a good product.

Figure 24.1. Seven-stage AI adoption process.



Most change plans stop investing after Trial. The stages that actually determine whether benefit is realized — Proficiency, Advocacy, Institutionalization — are the ones most often left unfunded.

Workforce impact matrix

Assess every affected role against three questions before rollout, and route each to a different change treatment.

Impact category	Description	Change treatment
Task augmented (role unchanged)	AI assists an existing task; role and headcount unaffected	Training + trial support; measure acceptance/edit rate
Task redesigned (role reshaped)	The workflow changes shape; some tasks disappear, new oversight tasks appear	Formal role redesign, updated job description and KPIs, targeted reskilling
Role reduced (headcount impact)	AI absorbs enough volume that staffing levels change	Executive-sponsored transition plan; HR and legal engagement before communication
New role created	AI creates a new function (e.g. AI oversight, prompt/agent engineering)	Define role, sourcing plan (internal reskill vs. external hire), career path

HONESTY RULE

Do not let "task augmented, role unchanged" become the default answer for every use case because it is the easiest to communicate. If the business case (Chapter 6) books a productivity benefit from redeployed hours, the affected role has been redesigned, not merely augmented — classify it honestly and change-manage it accordingly.

Capability & role reference

Capability	Roles
AI product	AI Product Manager, Business Product Owner
Architecture	Enterprise AI Architect, Solution Architect
Engineering	AI Engineer, ML Engineer, Software Engineer
Data	Data Engineer, Data Steward
Evaluation	AI Evaluation Engineer, QA
Platform	AI Platform, MLOps/GenAIOps
Security	AI Security, Red Team
Governance	AI Risk, Responsible AI, Privacy, Legal
Economics	AI FinOps, Vendor/Commercial
Operations	AI SRE, Incident Manager

Use the Change Impact & Workforce Transition Worksheet (Appendix Q) to record the impact-category classification and change treatment for every affected role before a use case reaches the Pilot gate.

25

PART VI — DELIVERY & OVERSIGHT

AI Technical Debt & Continuous Improvement

AI systems accumulate a form of technical debt that traditional software debt trackers do not capture: stale evaluation sets, unpinned model versions, drifted retrieval indexes, and orphaned agents nobody re-certifies.

Debt type	Description	Consequence if unaddressed
Stale evaluation set	Golden/adversarial dataset has not been refreshed since a major workflow or data change	Evaluation results silently stop reflecting production reality
Unpinned / drifting model version	Provider ships a default-version update that is adopted without re-certification	Quality regression traced to a change nobody approved
Orphaned agent or tool grant	An agent or tool permission outlives the use case it was built for	Unused but still-live attack surface and audit gap
Retrieval index drift	Source documents changed but the index was not refreshed to the documented freshness SLO	Grounded answers cite outdated or superseded information
Undocumented prompt/config changes	Production prompt or config edited outside the versioned registry (Ch.14)	No audit trail; regression cannot be isolated to a specific change
Deferred control debt	A control from the risk register (Ch.16, Appendix D) was accepted as a temporary exception and never closed	Accepted risk becomes permanent, unreviewed risk

Technical debt index

Track the six debt types above as a scored index per production AI system, refreshed on the same cadence as the control re-certification in Chapter 16 — the companion workbook's *Technical Debt Index* sheet operationalizes this scoring.

- ◆ Score each debt type 0 (none) to 3 (severe) per system; sum to a system-level debt index.
- ◆ Any system with two or more debt types scored 3 is escalated to the AI Risk & Architecture Review Board (Chapter 2) regardless of its risk tier.
- ◆ Debt-paydown work competes for the same backlog as new features — do not let it become permanently deprioritized "someday" work.
- ◆ Report the portfolio-aggregate debt index on the CIO/CDAO dashboard tier (Chapter 23) alongside spend and quality.

CONTINUOUS IMPROVEMENT RULE

A production AI system with a debt index that has only ever increased since launch is a system heading toward an incident (Chapter 18), not a stable asset. Falling debt should be a visible, celebrated engineering outcome — not an invisible one.

26

PART VI — DELIVERY & OVERSIGHT

Templates & Reference Artifacts

Templates operationalize this framework; the highest-leverage of them are reproduced in full, fillable form in Appendices A–Q.

Template	Purpose	Owner / reference
AI Strategy One-Pager	Executive alignment	CIO/CTO/CDAO
AI Transformation Charter	Funding & mandate	Executive Sponsor · App. A
Process-Transformation Decision Cascade	Instrument selection	AI PMO · Ch.4
AI Use-Case Canvas	Standard intake	Business Product Owner
Use-Case Scoring Matrix	Portfolio prioritization	AI PMO
AI Business Case & Benefits Realization	Funded case + tracking	Finance / Sponsor · App. L
AI System Card	System inventory	Product / Architecture · App. B
Architecture Decision Record (ADR)	Design decisions	Enterprise Architecture · App. I
AI Infrastructure Sizing Worksheet	Compute/serving planning	AI Platform · Ch.9
AI Risk Assessment	Risk tier + controls	Risk / Compliance
AI Risk Register	Standing risk log	Risk / Compliance · App. D
Model Evaluation Plan	Acceptance criteria	AI Engineering · App. C
Model Selection Matrix	Model choice	AI Architecture · App. J
Golden Dataset Register	Regression data	Evaluation Lead
Prompt / Model Change Record	Version + approval	AI Platform
RAG Design Checklist	Knowledge architecture	Data / AI Architect
Agent Tool Register	Permissions	Agent Platform · App. E
Enterprise AI Platform Blueprint Worksheet	Four-plane roadmap	AI Platform · Ch.12
Build / Buy / Partner Scorecard	Sourcing decision	Architecture / Procurement · App. K
Vendor Scorecard	Procurement	Architecture / Procurement
Vendor Due Diligence Checklist	Pre-contract review	Procurement / Legal · App. O
AI Incident Runbook	Production response	SRE / Security
AI Incident Report	Structured incident record	SRE / Security · App. N

Template	Purpose	Owner / reference
AI Resilience & DR Matrix	Failure-mode planning	AI Platform SRE · App. P
TCO Model	Business case	Finance / FinOps
AI FinOps Dashboard	Spend / unit economics	FinOps
Executive AI Dashboard	Transformation oversight	AI Steering
AI Maturity Assessment Worksheet	Maturity scoring	AI CoE · App. M
Team Topology & Funding Worksheet	Operating-model sizing	AI CoE · Ch.19
Technical Debt Index	System debt scoring	AI Platform · Ch.25
Change Impact & Workforce Transition Worksheet	Role impact classification	HR / Change · App. Q
AI Capability Heatmap	Maturity assessment	AI CoE

The companion workbook (*Enterprise AI Transformation — Templates & Dashboard.xlsx*) operationalizes the Use-Case Portfolio, TCO Model, Executive AI Dashboard, Roadmap, RACI, AI Risk Register, Model Registry, Model Selection Matrix, Build-Buy-Partner, Business Case, Maturity Assessment, Team Topology & Funding, Technical Debt Index and Resilience & DR sheets with live formulas.

27

PART VI — DELIVERY & OVERSIGHT

Reference Architecture Patterns

Knowledge Assistant <i>When to use:</i> Internal knowledge <i>Core components:</i> RAG, ACL search, model gateway, evals	Document Intelligence <i>When to use:</i> Claims / invoices / contracts <i>Core components:</i> OCR, extraction, validation, workflow	Coding Assistant <i>When to use:</i> Engineering productivity <i>Core components:</i> Code model, IDE, policy, telemetry
Customer Service Copilot <i>When to use:</i> Agent assist <i>Core components:</i> CRM context, retrieval, model, human workflow	Agentic Operations <i>When to use:</i> Multi-step workflows <i>Core components:</i> Agent runtime, tools/APIs, approval gates	Decision Support <i>When to use:</i> High-value recommendations <i>Core components:</i> Predictive/GenAI, data layer, human review
AI Software Delivery <i>When to use:</i> Engineering automation <i>Core components:</i> Coding model, tests, CI/CD, evals	Multi-model Gateway <i>When to use:</i> Provider flexibility <i>Core components:</i> Routing, policy, quotas, telemetry	Regulated Decision Support (Ch.4 pattern) <i>When to use:</i> Credit, underwriting, eligibility decisions <i>Core components:</i> ML decision system + GenAI-drafted explanation + human sign-off
AI Incident Response Copilot <i>When to use:</i> Faster, consistent incident handling <i>Core components:</i> Trace retrieval, runbook grounding, human-approved actions only		

App. A

APPENDICES — REFERENCE TEMPLATES

AI Transformation Charter

Complete this one-page charter with the executive sponsor before funding is committed.

Objective	
Sponsor	
Business outcomes	
Risk appetite	
Scope	
Funding	
Target maturity	
12-month outcomes	
24-month outcomes	
Decision rights	

App. B

APPENDICES — REFERENCE TEMPLATES

AI System Card

One card per production AI system — the minimum inventory record for governance, audit and incident response.

System ID	
Business / technical owner	
Purpose / users	
Risk tier	
Data	
Model	
Prompt / config	
Retrieval	
Tools	
Evaluation	
Security	
Human oversight	
SLOs	
Economics	
Change policy	

App. C

APPENDICES — REFERENCE TEMPLATES

Model Evaluation Plan

Define acceptance criteria before implementation — not after.

Use case	
Business metric	
Golden dataset	
Correctness threshold	
Grounding threshold	
Safety threshold	
Security tests	
Agent/tool tests	
Latency SLO	
Cost/task target	
Human evaluation	
Release gate	

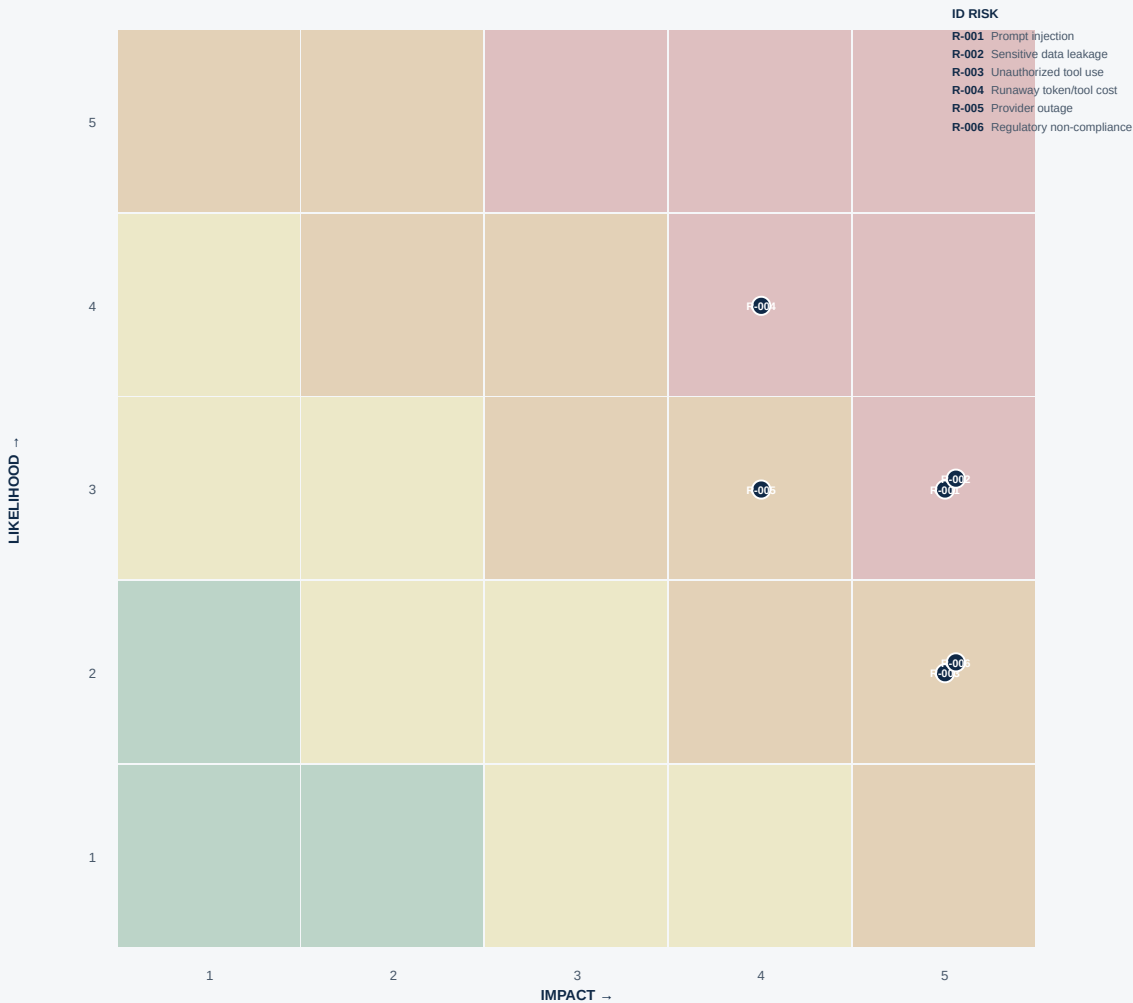
App. D

APPENDICES — REFERENCE TEMPLATES

AI Risk Register

Ten standing risk categories should appear on every enterprise AI risk register, scored by likelihood × impact and tiered for escalation.

Figure D.1. Illustrative risk heatmap — sample scoring from the companion workbook.



Likelihood and impact scored 1 (low) to 5 (high); tier and control ownership are recorded in the register below and in the companion workbook's Risk Register sheet.

WORKED EXAMPLE (POPULATED) — MIRRORS THE COMPANION WORKBOOK'S RISK REGISTER SHEET

ID	Risk	Likelihood	Impact	Tier	Control	Owner
R-001	Prompt injection	3	5	High	Isolation + adversarial tests	CISO
R-002	Sensitive data leakage	3	5	High	DLP + ACL-aware retrieval	CISO

ID	Risk	Likelihood	Impact	Tier	Control	Owner
R-003	Unauthorized tool use	2	5	High	Allow-list + least privilege	AI Platform
R-004	Runaway token/tool cost	4	4	High	Budgets + quotas + loop limits	FinOps
R-005	Provider outage	3	4	Moderate	Fallback routing	Platform
R-006	Regulatory non-compliance	2	5	High	Inventory + legal/risk review	Risk/Legal

Fillable register — additional standing categories

Risk	Likelihood	Impact	Tier	Control	Owner	Status
Incorrect action						
Model / data drift						
IP / copyright						
Bias / fairness						

App. E

APPENDICES — REFERENCE TEMPLATES

Agent Tool Register

Every tool an agent may call is registered, scoped and rate-limited — no implicit trust. Re-certify each entry on the cadence set by the agent lifecycle in Chapter 11.

Tool	Purpose	Data access	Write access	Approval	Rate limit	Owner	Next re-certification
CRM lookup							
CRM update							
Payment action							
Ticket creation							
Knowledge search							
Document generation							
Email / notification send							
Case escalation							
Inventory adjustment							
External API call							

Cross-reference: use the AI Incident Report (Appendix N) if a registered tool is implicated in an incident, and record the finding against this register's "Status" history at the next re-certification.

App. F

APPENDICES — REFERENCE TEMPLATES

Production Readiness Checklist

All fourteen items pass before an AI system moves from pilot to production.

☐ Business owner + KPI assigned

☐ AI system registered / risk-tiered

☐ Data / privacy / legal reviews complete

☐ Threat model / security tests complete

☐ Model / prompt versions pinned

☐ Golden dataset / regression suite established

☐ Quality / safety thresholds passed

☐ Observability / audit logging enabled

☐ Cost budget / unit economics established

☐ Human escalation + incident runbook tested

☐ Rollback / fallback validated

☐ SLOs / on-call ownership defined

☐ Vendor / commercial terms approved

☐ Post-launch review scheduled

App. G

APPENDICES — REFERENCE TEMPLATES

Source Register

REVISION NOTE

Version 1.2 editorial refresh (24 August 2026): the register below was rebuilt with publisher names, publication dates and direct source URLs so every citation is independently verifiable rather than name-only. In the course of adding URLs, the OWASP GenAI/LLM Top 10 2026 publication date [R4] was reconciled against the primary OWASP resource page to **3 August 2026** — superseding the 6 August 2026 date carried in the prior revision, which had been taken from secondary press coverage rather than the primary artifact. The Executive Summary's platform-services list was also reconciled to the nine services actually defined in Chapter 14, and figure numbering across the document was converted from a single global sequence to chapter-scoped numbering (e.g. Figure 9.1, Figure 9.2) to remove duplicate figure numbers.

Version 1.2 substantive update (24 August 2026): incorporates a full independent review of v1.1 — the Use Case Portfolio scoring formula in the companion workbook was corrected to implement the documented 25/15/15/15/10/10 weighting with Risk and Regulatory Sensitivity evaluated as separate gates (Chapter 5, Appendix D); nine new appendices (I–Q) and seven new/substantially expanded chapters were added to make the framework more operational. No new external primary sources were introduced by that update; it operationalized the existing evidence base below.

Version 1.1 revalidation (24 August 2026): the claim of a 2026 revision to NIST AI 600-1 [R2] was removed pending confirmation (the 2024 Generative AI Profile remains current at time of writing), and the EU AI Act "Digital Omnibus" deadline deferral [R12] was added.

Ref	Source	Publisher	Date	URL
[R1]	AI Risk Management Framework (AI RMF 1.0), NIST AI 100-1	NIST	2023	https://doi.org/10.6028/NIST.AI.100-1
[R2]	Generative AI Profile, NIST AI 600-1	NIST	26 Jul 2024	https://doi.org/10.6028/NIST.AI.600-1
[R3]	ISO/IEC 42001:2023 — AI management system	ISO/IEC	2023	https://www.iso.org/standard/81230.html
[R4]	GenAI/LLM Top 10 2026	OWASP Gen AI Security Project	3 Aug 2026	https://genai.owasp.org/resource/owasp-genai-llm-top-10-2026/
[R5]	Top 10 for LLM Applications 2025	OWASP	2025	https://owasp.org/www-project-top-10-for-large-language-model-applications/
[R6]	Cloud Adoption Framework — AI agent adoption guidance	Microsoft	2026	https://learn.microsoft.com/en-us/azure/cloud-adoption-framework/ai-agents/
[R7]	FinOps for AI (Technology Category)	FinOps Foundation	2026	https://www.finops.org/framework/technology-categories/ai/

Ref	Source	Publisher	Date	URL
[R8]	FinOps Framework	FinOps Foundation	2026	https://www.finops.org/framework/
[R9]	API Pricing	OpenAI	Accessed Aug 2026	https://openai.com/api/pricing/
[R10]	API Pricing	Anthropic	Accessed Aug 2026	https://www.anthropic.com/pricing
[R11]	Building an enterprise-ready generative AI platform on AWS	AWS Prescriptive Guidance	2026	https://docs.aws.amazon.com/prescriptive-guidance/latest/strategy-enterprise-ready-gen-ai-platform/introduction.html
[R12]	AI Omnibus enters into force — Annex III → 2 Dec 2027; Annex I → 2 Aug 2028	European Commission	2026	https://digital-strategy.ec.europa.eu/en/news/ai-omnibus-enters-force

All URLs accessed 24 August 2026 for this revision. Live pages — pricing, benchmark rankings, standards pages and regulatory trackers — change without notice; revalidate before relying on a citation in procurement, architecture approval or compliance work.

EVIDENCE RULE

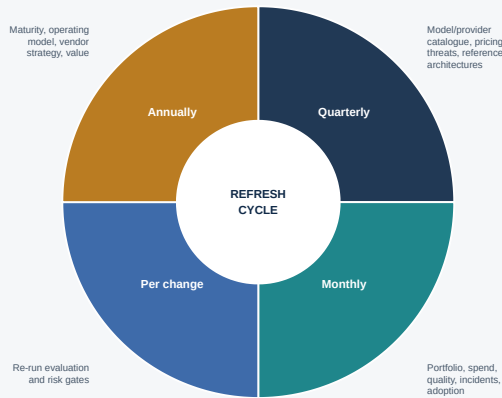
Standards and framework statements should be checked against current authoritative sources. Product capabilities, model availability, prices, limits and regional availability should always be revalidated before architecture approval or procurement.

App. H

APPENDICES — REFERENCE TEMPLATES

Framework Refresh Cycle

Figure H.1. Framework refresh cadence.



Four cadences plus trigger-based updates keep the framework current between annual reissues.

- ◆ **Quarterly:** refresh model/provider catalogue, pricing, threats and reference architectures.
- ◆ **Monthly:** review portfolio, spend, quality, incidents and adoption.
- ◆ **Per material production change:** re-run relevant evaluation and risk gates.
- ◆ **Annually:** reassess maturity, operating model, vendor strategy and value.
- ◆ **Trigger-based:** immediately update controls for material regulatory, security, provider or model changes.

App. I

APPENDICES — REFERENCE TEMPLATES

Architecture Decision Record (ADR)

Record every material AI architecture decision (model choice, build/buy, infrastructure pattern, agent autonomy tier) in this format — it is the evidence trail the AI Risk & Architecture Review Board (Chapter 2) reviews at each gate.

ADR ID	
Title	
Status (Proposed / Accepted / Superseded)	
Context	
Decision	
Options considered	
Rationale	
Consequences	
Related risk/control IDs	
Owner	
Review date	

App. J

APPENDICES — REFERENCE TEMPLATES

Model Selection Matrix

Worked example mirroring the companion workbook’s Model Selection Matrix sheet — score each candidate 1–5 per dimension, weighted per Chapter 13.

ILLUSTRATIVE — RECALIBRATE WEIGHTS AND RESCORE AGAINST REPRESENTATIVE ENTERPRISE DATA

Dimension	Weight	Model A (frontier)	Model B (mid-tier)	Open-Weight Model
Task-specific quality	20%	5	4	3
Reasoning	10%	5	3	3
Tool calling	10%	5	4	3
Latency	10%	3	4	4
Cost	15%	2	4	5
Security / data controls	10%	4	4	3
Data residency controls	10%	3	4	5
Context window	5%	5	4	4
Multimodal support	5%	5	3	2
Portability / exit	5%	2	3	5

SCORING FORMULA

Weighted total = $\Sigma(\text{weight} \times \text{score})$ per column; the companion workbook computes this automatically and flags if weights do not sum to 100%.

App. K

APPENDICES — REFERENCE TEMPLATES

Build / Buy / Partner / Open-Weight Scorecard

Worked example mirroring the companion workbook's Build-Buy-Partner sheet — score each sourcing option against the criteria in Chapter 21.

ILLUSTRATIVE — RECALIBRATE PER CAPABILITY UNDER EVALUATION

Criterion	Weight	Buy (SaaS)	Configure	Build	Partner	Open-Weight / Self-Host
Differentiation	20%	1	2	5	3	4
Speed to value	15%	5	4	2	3	2
Cost (near-term)	15%	3	3	2	3	2
Cost (at scale)	10%	2	3	4	3	5
Control	15%	1	2	5	3	5
Risk	10%	4	3	2	3	2
Portability / exit	10%	1	2	5	2	5
Internal skills required	5%	5	4	1	3	2

App. L

APPENDICES — REFERENCE TEMPLATES

AI Business Case & Benefits Realization Template

Complete alongside the Use-Case Scoring Matrix (Chapter 5) before a use case is funded past PoC — live in the companion workbook's Business Case sheet.

Use case

Sponsor

One-time investment

Annual benefit (by category)

Annual run cost

Net annual benefit

Payback period (months)

3-year net benefit

3-year ROI %

Benefits-realization owner

Re-baseline date
(Pilot → Production gate)

Quarterly realization tracker

Metric	Q1	Q2	Q3	Q4
Target benefit (\$)				
Realized benefit (\$)				
Realization %				

App. M

APPENDICES — REFERENCE TEMPLATES

AI Maturity Assessment Worksheet

Score each dimension 0–5 against the maturity ladder in Chapter 3; overall level is capped at the lowest-scoring dimension, not the weighted average.

Dimension	Score (0–5)	Evidence
Strategy & sponsorship		
Portfolio & governance		
Data foundation		
Platform & engineering		
Risk, security & compliance		
Operating model & skills		
Economics & FinOps		
Adoption & change		

App. N

APPENDICES — REFERENCE TEMPLATES

AI Incident Report

Complete for every SEV-1/SEV-2 incident per the classification and severity matrix in Chapter 18; retain SEV-3/SEV-4 in the evaluation retrospective log.

Incident ID

Date/time detected

Incident class
(Content/Security/Autonomy/Availability/Compliance)

Severity (SEV-1 to SEV-4)

Affected system(s) / System
Card ref.

Detection method

Containment action taken

Root cause

Business impact

Regulatory notification
required? (Y/N)

Regression-set case added?
(Y/N)

Closure date

Post-incident review owner

App. O

APPENDICES — REFERENCE TEMPLATES

Vendor Due Diligence Checklist

Complete before contract signature for any AI vendor scored via the vendor selection weighting in Chapter 21.

☐	Data handling, retention and training-use terms reviewed by Privacy/Legal
☐	Data residency and cross-border transfer terms confirmed against enterprise policy
☐	Security posture reviewed (SOC 2 / ISO 27001 or equivalent, penetration test summary)
☐	Model/output IP and liability terms reviewed
☐	SLA and uptime commitments reviewed against the resilience matrix (Appendix P)
☐	Exit / portability terms and data-export mechanism confirmed
☐	Sub-processor and fourth-party AI dependencies disclosed
☐	Pricing model and rate-change notice terms reviewed against the TCO model (Chapter 20)
☐	Vendor financial viability / concentration risk assessed
☐	Incident notification obligations reviewed against Chapter 18's response SLAs
☐	Regulatory/compliance representations reviewed (Chapter 16)
☐	Reference customer check completed for comparable risk-tier workload

App. P

APPENDICES — REFERENCE TEMPLATES

AI Resilience & Disaster Recovery Matrix

Worked example mirroring the companion workbook's Resilience & DR sheet and the failure modes introduced in Chapter 9.

Failure mode	Primary control	Recovery target	Last test date
<i>Model/provider outage</i>	<i>Multi-provider fallback routing at the AI gateway</i>	<i>Minutes</i>	
<i>Model quality regression (silent provider update)</i>	<i>Pinned versions + regression-suite gate</i>	<i>One evaluation cycle</i>	
<i>Knowledge index corruption / staleness</i>	<i>Point-in-time snapshots + freshness SLO monitoring</i>	<i>Within RTO of last-known-good</i>	
<i>Region/zone failure</i>	<i>Multi-region deployment (tier-1) / documented degraded mode (other)</i>	<i>Per enterprise DR policy tier</i>	
<i>Runaway cost event</i>	<i>Hard spend circuit-breakers at the AI gateway</i>	<i>Minutes</i>	

RESILIENCE RULE

An untested fallback is an assumption, not a control. Record the last test date for every row and flag any row untested in the last quarter.

App. Q

APPENDICES — REFERENCE TEMPLATES

Change Impact & Workforce Transition Worksheet

Complete for every affected role before a use case reaches the Pilot gate — classify honestly per Chapter 24; a productivity benefit booked in the business case (Chapter 6) implies the role was redesigned, not merely augmented.

Role	Impact category (Augmented/Redesigned/Reduced/New)	Description	Change treatment	Owner